



*Asociación Profesional del Cuerpo Superior
de Sistemas y Tecnologías de la Información
de la Administración del Estado*

Temas Específicos para la preparación de la Oposición al Cuerpo
Superior de Sistemas y Tecnologías de la Información de la
Administración del Estado

TEMAS ESPECÍFICOS IV: Redes, Comunicaciones e Internet

**Tema 131. Acceso remoto a sistemas corporativos: gestión de
identidades, single sign-on y teletrabajo**

AUTOR: Alberto Ramallo Lucini

REVISOR: Carlos A. Molina Carrón

TABLA DE CONTENIDOS

1.	Introducción	3
2.	Gestión de identidad y accesos (IAM)	5
2.1.	Definiciones	5
2.2.	Procedimiento de control de accesos	6
2.3.	Modelos de control de accesos	8
3.	IAM en el entorno corporativo tradicional (red local)	10
3.1.	Gestión de la identidad: servicios de directorio	10
3.2.	Single Sign On (SSO)	16
4.	Acceso remoto a sistemas corporativos	23
4.1.	Acceso remoto usando RADIUS	23
4.2.	Acceso remoto usando TACACS+	25
4.3.	Acceso remoto usando PAP	26
5.	IAM en el entorno corporativo moderno (nube)	27
5.1.	Características y capacidades de las soluciones IAM modernas	28
5.2.	Federación de identidades	28
5.3.	SAML 2	29
5.4.	Oauth 2 y OpenID Connect	33
5.5.	Soluciones IAM para entornos de nube híbrida y multinube	39
6.	Gestión de identidad en las AAPP	42
6.1.	AAPP en España	42
6.2.	Unión Europea	44
7.	Teletrabajo y trabajo en movilidad	46
7.1.	Teletrabajo y Administración Pública: Marco Normativo	46
7.2.	Trabajo en movilidad o itinerancia	47
7.3.	Tecnologías que permiten el acceso remoto a los sistemas corporativos	47
8.	Conclusiones	56
9.	Preguntas de test	57
10.	Respuestas a las preguntas de test	61
11.	Glosario	63
12.	Bibliografía	65

1. Introducción

En un mundo ideal, no sería necesario controlar el acceso a lo importante o valioso. En ese mundo ideal ni siquiera se necesitarían cerraduras en las puertas de las casas o las empresas. Podríamos confiar los unos en los otros y nadie accedería a aquello que no es suyo.

Por desgracia, ésta no es la realidad ni en nuestro hogar ni en el trabajo. En el mundo real, tanto en nuestra vida privada como en las empresas y en las Administraciones Públicas, es necesario proteger datos, sistemas, redes y otros activos de todo tipo de amenazas. El control de accesos es el conjunto de técnicas que nos permiten poner cerraduras en las puertas (virtuales), evitando el acceso no autorizado y la exposición de los activos de la organización.

Hoy en día, cualquier organización cuenta con un gran número de aplicaciones y un cierto grado de rotación entre su personal (altas, bajas, modificaciones...). Cada vez más se trabaja en entornos de nube híbrida y de múltiples nubes (multicloud), y además en los últimos años se ha producido un importante aumento de los usuarios que se conectan desde fuera de la red interna, típicamente aquellos que teletrabajan.

Para colmo, la normativa aplicable a las aplicaciones informáticas (LOPDGDD, LSSI...) introduce exigencias relacionadas con la identidad, el acceso a las aplicaciones, y la custodia y transmisión de ciertos tipos de datos, incluyendo auditoría y trazabilidad de las acciones realizadas por los usuarios.

Todo ello convierte a la gestión de la identidad y el control de los accesos en la organización en actividades de gran complejidad y ha conducido al desarrollo de herramientas especializadas en gestión de la identidad y el control del acceso a los recursos de la organización. Estas herramientas aspiran a centralizar estas funciones en un único lugar.

Este tema intenta arrojar luz sobre algunas soluciones y productos que se pueden usar (o se están usando) hoy en día para facilitar la gestión de identidades y el acceso de los usuarios. Es por ello que abarca muchos conceptos: identidad, seguridad, teletrabajo... y un gran abanico de tecnologías. Se ha intentado abordar este tema teniendo en cuenta el resto del temario, para no duplicar esfuerzos y contenidos sin dejar de abarcar todos aquéllos que puedan no estar reflejados en otras partes del mismo.

Para poder aprovecharlo de una forma óptima, se debe estudiar en conjunto con los que abordan conceptos con los que tiene relación. En concreto, siguiendo el temario de la Convocatoria 2021-2022 del Cuerpo Superior de Sistemas y Tecnologías de la Información, se deben tener muy presentes los temas de:

- Auditoría Informática: tema 38
- Servicios de directorio: temas 80 y 122
- Infraestructura de clave pública (PKI), mecanismos de identificación y firma: tema 81
- Adaptación de aplicaciones y entornos a los requisitos de la normativa de protección de datos según los niveles de seguridad: tema 82

- Virtualización de puestos de trabajo: tema 132
- Herramientas de trabajo colaborativo: tema 133
- Seguridad en redes, en particular el cifrado (redes seguras, VPN): tema 125

Además, no se deben olvidar los que versan sobre legislación: Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales; Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas; Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad; y sus desarrollos reglamentarios.

2. Gestión de identidad y accesos (IAM)

2.1. Definiciones

En esencia, el término **acceso** se refiere a la capacidad de un **sujeto** para interactuar con un **objeto**.

El sujeto puede ser muchas cosas diferentes: puede ser un usuario, lógicamente, pero también puede ser un sistema, un proceso o una aplicación. En todo caso, el sujeto solicita acceso al objeto.

El objeto es un recurso al que el sujeto desea acceder. Algunos objetos habituales son ficheros, elementos de una red, datos, impresoras, etc. En general se considera que hay 3 categorías principales de objetos: información, tecnología (aplicaciones, sistemas, redes...) y ubicaciones físicas (edificios, salas...).

El **control de accesos** es la formalización de reglas que rigen la concesión o denegación de dicho acceso. El control de accesos define las interacciones permitidas entre los sujetos y los objetos. Se basa en la concesión de permisos a un sujeto sobre un objeto.

La **gestión de identidades** (IdM en inglés) es el proceso de crear, mantener y revocar las cuentas de usuario y los mecanismos que permiten autenticar a los usuarios. En este sentido, la gestión de identidades es diferente del control de accesos: la primera permite confirmar que un sujeto es quien dice ser (autenticación) mientras que el segundo permite restringir sus accesos únicamente a aquellos objetos que le están permitidos.

En la práctica los conceptos de gestión de identidades y de control de accesos están estrechamente interrelacionados y es muy difícil pretender estudiar uno sin el otro. Por esta razón lo más habitual es referirse a ambos indistintamente bajo el término más general de Gestión de Identidades y Accesos, en inglés **Identity and Access Management (IAM)**.

Un sistema de control de accesos bien definido se compone de 3 elementos:

- **Políticas:** afirmaciones claras de las reglas de negocio relativas al acceso a los recursos.
- **Procedimientos:** son los métodos *no tecnológicos* (manuales) que se usan en la aplicación de las políticas. Ejemplos de procedimientos pueden ser la comprobación de los datos de una solicitud de alta en una aplicación (quién lo solicita, comprobación de los datos del sujeto, etc.) o un procedimiento periódico de comprobación de la vigencia de los datos de los usuarios en un sistema.
- **Herramientas:** son los métodos *tecnológicos* que se usan en la aplicación de las políticas. Por ejemplo, los sistemas de control que proporcionan un sistema operativo o una cabina de almacenamiento para el acceso a los ficheros que almacenan; o un firewall que controla los accesos a un segmento de red.

Las organizaciones, tanto empresas como Administraciones Públicas, suelen tener políticas estrictas que definen quien puede acceder a qué información. Para aplicar de manera efectiva estas políticas utilizan una combinación de procedimientos y herramientas.

Por ejemplo, en una organización podríamos encontrar una política que establece que el acceso a determinados documentos (como las fichas de los empleados) sólo es posible para los empleados autenticados y que rellenen un formulario describiendo la necesidad específica por la que deben acceder a dichos documentos y sólo bajo aprobación del responsable de dichos documentos. Una vez la solicitud aprobada, se les podría facilitar un usuario y contraseña temporales que les permitirá el acceso y registrar y almacenar todos los accesos realizados. El formulario y la aprobación (quizás también la generación del usuario y contraseña) son procedimientos, mientras que la Intranet y los datos del usuario y contraseña, así como el registro de los accesos, son herramientas.

Se habla de una "triple A", **AAA (authentication, authorization, accounting)**, que son los 3 elementos de los sistemas de control de accesos:

- autenticación: asegurar que el usuario es quien dice ser; es decir, comprobar que la identidad que declara es cierta;
- autorización: asegurar que el usuario, una vez confirmada su identidad, tiene acceso al recurso al que lo solicita;
- registro (accounting): guardar registros de las acciones realizadas por el usuario.

2.2. Procedimiento de control de accesos

El procedimiento de control de accesos sigue siempre los mismos pasos:

- identificación: el sujeto declara su identidad. Es decir, se identifica ante el sistema de control de accesos;
- autenticación: el sistema de control de accesos comprueba de alguna forma la identidad del sujeto;
- autorización: el sistema, a la vista de la identidad (comprobada) del sujeto, decide si permitir o denegar el acceso al objeto.

Identificación

El sistema tiene que ser capaz de identificar, es decir, de aplicar una etiqueta, tanto al sujeto como al objeto. La etiqueta es simplemente una descripción, pero tiene que cumplir la condición de ser única. Por ejemplo, un usuario podría identificarse como *arl123*, como *marius* o cualquier otro identificador (etiqueta), siempre y cuando sea único dentro del sistema de control de accesos.

Autenticación

El segundo de estos pasos se suele realizar *entre bambalinas*, es decir, oculto a la vista del sujeto. Como usuarios humanos, muchas veces tenemos acceso a un determinado fichero o recurso en la red interna sin ser conscientes de que este procedimiento está teniendo lugar. No obstante, incluso si no lo vemos, el procedimiento tiene lugar. Más adelante veremos los mecanismos que permiten que estas interacciones nos pasen generalmente desapercibidas.

Para la autenticación muchas veces es suficiente con un único factor. Sin embargo, es posible utilizar varios. Los tres más habituales son:

- algo que se conoce, generalmente una contraseña
- algo que se tiene, que puede ser un certificado digital, un token almacenado, un dispositivo físico, una tarjeta inteligente...
- algo que se es, es decir, elementos biométricos como las huellas digitales, el iris u otro.

Autorización

Por último, una vez identificados el sujeto y el objeto, y una vez el sistema de control de accesos ha podido autenticar dicha identidad, este sistema debe determinar si el sujeto está autorizado a acceder al recurso que solicita.

La autorización es un conjunto de permisos definidos para un sujeto sobre un objeto concreto. Normalmente se basan en la identidad del sujeto. Por ejemplo, un encargado en el departamento de Recursos Humanos de una organización podría tener acceso a las fichas de los empleados, pero no tener permisos para editar el balance contable anual de la organización.

Cada sistema, aplicación o servicio podrá definir sus propios **niveles de autorización**. Tradicionalmente se consideran cuatro niveles básicos de acceso, por ejemplo, en los sistemas de ficheros:

- administrativo: leer, escribir (modificar), crear y suprimir en una ubicación concreta;
- autor: leer y escribir los archivos de los que es propietario;
- sólo lectura: leer, pero no escribir;
- sin acceso: denegación completa del acceso.

Por supuesto, otros sistemas o aplicaciones pueden definir otros niveles con mayor granularidad, aunque los cuatro niveles que se acaban de citar son muy habituales. Por poner algunos ejemplos de otros permisos más complejos, podemos citar los siguientes:

- ejecutar: permiso para ejecutar un archivo;
- modificar permisos: permiso para conceder o retirar permisos a otros usuarios.

A menudo los permisos sobre un objeto se describen utilizando una lista de control de acceso (**ACL, access control list**). Una ACL consiste en un listado de los permisos de los diferentes sujetos sobre el objeto. Cada una de las entradas en la ACL es una **ACE (access control entry)**. Una ACE consistirá en el identificador de un sujeto y uno o varios niveles de autorización. En el contexto de las ACL, el identificador de un sujeto a menudo se denomina **SID, Security Identifier**.

Podemos encontrar ACL en las aplicaciones, en los sistemas operativos y en los equipos de red tales como routers o firewalls. Por ejemplo, los sistemas operativos crean una ACL por cada recurso que gestionan (cada fichero, puerto, proceso, evento...) que lista los permisos de los sujetos sobre el mismo.

2.3. Modelos de control de accesos

A menudo no es viable ni eficiente definir los permisos para cada sujeto y para cada posible recurso. Esto es especialmente cierto a medida que las organizaciones crecen.

Una forma más eficiente de gestionarlos se consigue mediante el uso de grupos y de roles. Tanto los roles como los grupos son formas de agrupar a los usuarios basándose en algún criterio (la unidad en la que trabajan, su título, su cargo, etc.). Un mismo sujeto puede estar en varios grupos o disponer de varios roles a la vez.

Los permisos se conceden al grupo, y todos los individuos en el grupo tienen los mismos permisos con respecto a un mismo recurso.

- RBAC: role-based access control, control de accesos basado en roles.
- GBAC: group-based access control, control de accesos basado en grupos.

Esto no supone ninguna pérdida de control ni de seguridad. El sujeto individual tiene que identificarse y autenticarse con su nombre de usuario único, y se guardan trazas (accounting) de sus acciones utilizando este identificador único.

Obsérvese que no hay una diferencia práctica entre «roles» y «grupos». Ambos términos se usan comúnmente, y en la práctica vienen a ser sinónimos. Esto es así porque, si varios usuarios comparten un mismo rol, siempre podemos considerar que son parte del mismo grupo. Por lo tanto, aunque en ocasiones encontremos un término y en ocasiones otro, a efectos prácticos no hay diferencia.

En conjunto, existen los siguientes modelos de control de accesos:

- DAC, Discretionary Access Control: el propietario del recurso decide la política. Es el modelo más usado. Un sujeto con ciertos permisos sobre el objeto puede pasar esos permisos a otros sujetos. Incluso pueden delegar la capacidad de modificar los permisos a otros sujetos. El control se mantiene usando ACLs. Con este método no se necesitan administradores del sistema que determinen la importancia de un documento o recurso. La responsabilidad queda en manos del propietario del recurso. Este es el modelo que ofrecen prácticamente todos los sistemas operativos. Sin embargo, para sistemas más complejos, sujetos a requisitos de cumplimiento normativo o de seguridad, este modelo suele ser insuficiente.
- MAC, Mandatory Access Control: política definida por el sistema. Cada objeto tiene una etiqueta que indica su grado de sensibilidad, y en función de la etiqueta, sólo determinados usuarios pueden acceder al objeto. Por ejemplo, un sujeto que puede acceder a documentación *Confidencial* no podría acceder a un documento *Top Secret*. Los modelos MAC se usan a veces en entornos de seguridad nacional. Este modelo no usa ACLs, y los usuarios que gozan de un nivel de acceso suficiente para acceder a un documento no pueden delegar sus permisos ni conceder acceso a un usuario que no dispone del nivel suficiente. Tanto el sujeto como el objeto tienen que tener un nivel de acceso asignado («etiquetas» de acceso).

- RBAC, Role Based Access Control: política definida según las funciones que el usuario desempeña en la organización (roles y grupos a los que pertenece). Por ejemplo, roles diferentes para usuarios de Recursos Humanos o de Gestión Financiera. Este modelo es bastante habitual en las organizaciones actuales y en sistemas complejos. Es más complejo que el modelo DAC, pues obliga a prever una serie de procedimientos:
 - asignación de roles: todos los usuarios activos tienen que tener al menos un rol asignado. Es necesario prever cómo se va a asignar este rol al usuario.
 - autorización del rol: a menudo, se pide una autorización de algún usuario previamente registrado en el sistema y conocido. Es muy habitual, por ejemplo, pedir la autorización del responsable de la unidad en la que trabaja el sujeto. Tras la autorización, se asigna el rol al usuario, que ya puede acceder a la aplicación.
 - autorización de la transacción: cada transacción que se quiera hacer (consultas, modificaciones en los datos, envío de mensajes, etc.) tiene asignados uno o más roles para los que la transacción está autorizada.
- ABAC, Attribute Based Access Control: la política se define según las características del sujeto. Por ejemplo, si está utilizando un dispositivo corporativo y con el software de seguridad actualizado o si está utilizando su propio dispositivo bajo una política BYOD; o, por ejemplo, un sistema podría estar disponible únicamente para usuarios de una determinada unidad administrativa; o únicamente para ciudadanos empadronados en una ciudad concreta. Otro ejemplo de ABAC sería el control de accesos basado en la historia (HBAC), que toma en consideración la actividad pasada del usuario al tomar decisiones sobre sus accesos. Por ejemplo, un usuario que nunca accede a una aplicación desde fuera de la red corporativa, de repente intenta acceder desde un país extranjero. En general, el modelo ABAC se basa en el contexto. Está ganando popularidad en los últimos años. El paradigma de gestión de redes basado en la Confianza Cero (Zero Trust) propugna, entre otras cosas, la importancia fundamental de los modelos de control de accesos basados en atributos. Sin embargo, a día de hoy no está tan expandido como los modelos anteriores.
- RAdAC, Risk Adaptive Access Control: la política cambia dinámicamente, basada en el entorno (riesgo ambiental). Es un enfoque muy sofisticado en el que las decisiones sobre los accesos a recursos se basan en la evaluación del riesgo que dicho acceso conlleva. El resto de modelos simplemente conceden o deniegan el acceso basándose en reglas predefinidas. Con el modelo adaptativo es necesario valorar las características de las personas, las características de los elementos TIC (dispositivo, red, etc.), las características de los objetos (etiquetas de confidencialidad, etc.), los factores ambientales y otras heurísticas.

3. IAM en el entorno corporativo tradicional (red local)

Entendemos por «entorno tradicional» al entorno de red corporativo predominante durante los años 80, 90 y primera década de los 2000. Este entorno consistía en redes corporativas de área local divididas en *capas*, las cuales se separan entre sí mediante cortafuegos. Todas las aplicaciones se ejecutaban dentro de dicha red, y los usuarios sólo podían acceder a ellas desde dentro de la propia red. Un usuario no podía acceder a una aplicación desde su casa, salvo que se conectara mediante una VPN, escritorio virtual u otra tecnología que le permitiera *simular* estar dentro de la red interna.

El modelo tradicional todavía sigue siendo el modelo dominante, y en cualquier organización encontramos numerosas aplicaciones alojadas en el CPD y sólo accesibles desde dentro de la red local. Sin embargo, como veremos en el capítulo siguiente, desde la aparición del concepto de «la nube», este enfoque ha ido cambiando, y cada vez son más habituales los entornos *modernos* de nube híbrida y múltiples nubes.

En este capítulo se profundiza en las tecnologías usadas en el entorno local o *tradicional*. Estas tecnologías siguen utilizándose masivamente en los sistemas de la AGE y de muchas empresas. Sin embargo, no escalan bien en los escenarios de nube híbrida y de múltiples nubes, razón por la cual en la última década han surgido numerosas soluciones alternativas. Estas soluciones más modernas son objeto del siguiente capítulo.

3.1. Gestión de la identidad: servicios de directorio

En los entornos tradicionales que se acaban de describir, el componente principal para la gestión de la identidad y la autenticación es el *servicio de directorio*. Casi todas las organizaciones disponen de uno.

Un servicio de directorio permite centralizar la gestión de la identidad en un único punto. Es decir, en esencia un servicio de directorio es una base de datos centralizada de usuarios.

¿Por qué un servicio de directorio?

En ausencia de servicio de directorio, cada sistema debería tener su propia lista de usuarios. Por ejemplo, cada aplicación tendría una lista de usuarios almacenada posiblemente en su propia base de datos; los equipos de red, como firewalls o proxies, podrían también requerir su propia base de datos de usuarios; los ordenadores personales tendrían cada uno su propio usuario, y en cada impresora sería necesario dar de alta todos los usuarios que pueden utilizarla.

Intentemos imaginar por un segundo una organización así. Imaginemos, por ejemplo, que se incorpora un empleado nuevo con un contrato temporal en prácticas de 6 meses. En el momento en que se incorpora habría que crear su usuario en el PC; crear un usuario en la impresora del pasillo que va a utilizar; crear un usuario en cada una de las aplicaciones de negocio que va a utilizar, posiblemente varias; crear un usuario en el proxy de Internet que permite la navegación web; crear un usuario en la aplicación de fichajes y control horario; etc. Sería un trabajo enorme y muy repetitivo (hay que hacer esto con cada usuario nuevo).

Estas cuentas de usuario *dispersas* tendrían en principio cada una su propia contraseña o forma de autenticación, pues son todas independientes unas de otras. El trabajador podría poner la misma contraseña en todas ellas, pero aun así tendría que teclearla cada vez que fuera a entrar a uno de estos sistemas. Imaginemos la pesadilla que supondría para este empleado si existe una política de seguridad que le obliga a renovar su contraseña cada 6 meses y tiene que ir equipo por equipo cambiándola. Aunque semejante política sería muy difícil de llevar a cabo, pues habría que programarla en cada sistema individualmente (en las impresoras, en los PC, en las aplicaciones, en los equipos de red, etc.), al no haber un punto centralizado desde el que establecerla.

Pero además de la cantidad de trabajo y la incomodidad para los usuarios, también conlleva enormes riesgos de seguridad. Imaginemos que el responsable de este trabajador se percata de que necesita acceso a una aplicación nueva y lo solicita. Como en esta hipotética organización la gestión de identidades no está centralizada, de nuevo es necesario crear una cuenta de usuario adicional (otra más), esta vez en la base de datos de la aplicación en cuestión. Ídem si más tarde necesita acceder a otro edificio para realizar su trabajo. El riesgo de esto es que cuando este usuario termine su contrato y se le dé de baja, como se le han ido dando permisos a medida que se iba solicitando y no se ha apuntado en ningún sitio concreto (porque la gestión de identidades no está centralizada), el personal encargado de darlo de baja tiene que ir haciéndolo en cada aplicación y equipo, uno por uno. Es muy fácil que olvide borrarlo de alguna aplicación o sistema. En este caso el usuario, pese a no trabajar ya en la organización, retiene permisos que no debería tener, y que potencialmente le permitirían acceder a aplicaciones, edificios o redes de manera indebida. En una organización grande, esto no es un riesgo remoto; al contrario, es casi una certeza que acabará ocurriendo.

Es por todas estas razones que los sistemas de gestión de la identidad basados en servicios de directorio se expandieron rápidamente, y actualmente todas las organizaciones a partir de cierto número (pequeño) de empleados cuentan con uno.

Ventajas de implementar un sistema de gestión de identidad corporativo:

- Desde el punto de vista de la organización aumenta la satisfacción del trabajador, pues puede utilizar el mismo usuario y contraseña en numerosos sistemas.
- Desde el punto de vista legal ayuda a cumplir requisitos de auditoría y trazabilidad.
- Desde el punto de vista de la seguridad proporciona un punto de control esencial, permitiendo tener conocimiento de quién tiene acceso a qué recursos.

¿En qué consiste un servicio de directorio?

/!/ Puesto que existe un tema en el temario de la oposición, no se profundiza aquí en la definición, características y funcionamiento de los servicios de directorio. Para ello se aconseja la lectura de los temas 80 y 122, los apartados de servicios de directorio, servicios de directorio X500 y protocolos de directorio basados en LDAP, respectivamente.

De manera muy simplificada, un servicio de directorio es una base de datos que contiene todos los usuarios de la organización, así como recursos de la organización tales como grupos de usuarios, servidores, ordenadores, impresoras, etc.

Por supuesto, desde un servicio de directorio se pueden gestionar los grupos o roles disponibles para un usuario. El administrador puede asignar roles o grupos a un usuario, permitiéndole así acceder a determinados recursos.

En el servicio de directorio también se puede almacenar la contraseña de los usuarios, aunque si se desea una autenticación más sofisticada (p. ej., multifactor) es posible delegarla a otros sistemas como un servidor RADIUS. Esto se analiza con más detalle en el apartado 4.1 de este tema.

Un servicio de directorio ofrece una interfaz sencilla para la integración, típicamente usando el protocolo LDAP (aunque podrían ser otros). Las aplicaciones, equipos de red, impresoras y otros sistemas se integran con el servicio de directorio. Así, cuando un usuario intenta utilizar una impresora, ésta consulta su identidad y sus permisos al servicio de directorio. Igual cuando un usuario intenta acceder a una aplicación.

Como las aplicaciones y los equipos consultan al servicio de directorio cada vez que un usuario intenta utilizarlos, en el servicio de directorio se centralizan las trazas de todos los accesos que se realizan, por lo que es una fuente de información muy útil desde el punto de vista de la seguridad.

Un servicio de directorio sirve por lo tanto para gestionar la identidad, la autenticación (parcialmente) y a menudo la autorización de los usuarios. El ciclo de vida de la identidad es el siguiente:

- Alta de usuario: cuando se une a la organización. A menudo se le asigna un perfil básico. Un perfil es un rol o un conjunto de roles.
- Gestión de permisos: a medida que va necesitando permisos, se le van asignando nuevos roles o grupos.
- Actualización de la información del usuario: rutinas de cambios de contraseña y labores de administración, tales como cambios de nombre, la agregación y eliminación de cuentas de acceso, comprobar que el usuario sigue activo (a veces no se comunican las bajas), etc.
- Baja del usuario: cuando abandona la organización, se desactiva el usuario. Transcurrido un tiempo de precaución, se borra definitivamente.

Por supuesto, la implantación de un servicio de directorio no es una tarea sencilla. Instalarlo y poblarlo con datos no es complicado, pero en sí mismo eso no sirve para nada. Lo importante es conectar al servicio de directorio todas las aplicaciones de la organización, así como los equipos de microinformática (PC, impresoras, etc.) y los equipos de red (acceso WiFi, proxies, etc.).

Por esta razón el servicio de directorio es una de las piezas más críticas de los sistemas de una organización. Cuando una organización ha adoptado un producto concreto, es muy complicado cambiar a otro diferente, pues sería necesario modificar todas las aplicaciones (para integrarlas

con el nuevo producto), asegurarse de que es compatible con los equipos de microinformática y de red de la organización, etc.

Una de las posibles limitaciones de los directorios es la integración con sistemas *heredados*. Algunas aplicaciones desarrolladas en la propia organización con poco presupuesto, algunos sistemas operativos de red o algunos equipos antiguos podrían no soportar sistemas externos para la gestión de sus propios usuarios. En estos casos, en la organización quedarían *islotas* aislados para los cuales es necesario definir los usuarios manualmente. Los equipos de sistemas y de seguridad deberían conocerlos y valorar cuidadosamente los riesgos que pueden suponer estos sistemas.

Productos en el mercado

Los principales productos que existen en el mercado son:

- Microsoft Active Directory: es sin duda el producto más utilizado en la AGE y en la mayoría de organizaciones privadas, en los entornos *tradicionales* a los que se refiere este capítulo. Es un producto de una gran sofisticación y complejidad. Permite la definición de dominios, cada uno de los cuales equivale a una parte de la organización. Dentro de los dominios se establecen OUs (Organizational Unit), que permiten delegar la administración de usuarios. Dentro de las OU se pueden crear usuarios, grupos y equipos (*devices*), así como definir políticas para grupos (Group Policy objects). Parte del éxito de Active Directory se debe a que es gratuito (es un rol de Windows Server, que se instala sin coste adicional si se dispone de la licencia del servidor), y otra parte a su excelente integración con los equipos con sistema operativo Windows, tanto PC como servidores. Permite la replicación de los datos entre varios servidores, a fin de evitar la pérdida de servicio en caso de desastre en una ubicación. También permite la distribución de los datos entre diferentes máquinas, a fin de que los datos estén más cerca del lugar donde se van a utilizar y evitar latencias (por ejemplo, los datos de los empleados y recursos de una sucursal en Brasil pueden estar disponibles en una máquina local en la propia sucursal, replicados en la central en España). Dispone de funcionalidades para la creación de infraestructuras de clave pública, en inglés PKI (ADCS, Active Directory Certificate Services), para la autenticación segura de los usuarios. Permite la federación con otros Directorios Activos de otras organizaciones (ADFS, Active Directory Federation Services).
- Red Hat Directory Server: directorio basado en LDAP. Permite la gestión de la identidad y el control de los accesos de manera centralizada. También se organiza por dominios y permite la gestión de grupos y de roles. Usa ACL para asegurar que se apliquen las políticas de seguridad. Al igual que Microsoft AD, permite la replicación de los datos entre diferentes máquinas en diferentes ubicaciones para garantizar la disponibilidad. Permite la creación de infraestructuras de clave pública, en inglés PKI (usando Red Hat Certificate Systems), para la autenticación segura de los usuarios.
- Apache Directory Server: servidor de directorio en Java disponible bajo la licencia de Apache Software, es compatible con LDAPv3 certificado por el Open Group, soporta otros protocolos de red tal como Kerberos y NTP (*Network Time Protocol*).

Metadirectorios

En determinadas ocasiones, en una organización coexisten varios servicios de directorio o bases de datos que contienen información de los usuarios. Esto puede ocurrir, por ejemplo, a raíz de la fusión de dos organizaciones, cada una de las cuales dispone de su propio servicio de directorio. Como ya se comentó previamente, la migración de un servicio de directorio a otro es una tarea muy compleja, al igual que la integración de dos directorios (sobre todo si son de gran tamaño).

En estos casos, es muy posible que la organización se resigne a trabajar con dos o más directorios distintos sin llegar a integrarlos nunca, pero necesitará como mínimo poder sincronizar la información de las identidades que contiene cada uno de ellos. Esta sincronización permite modificar la información de un usuario en un único punto, y los cambios se propagan a cada uno de los directorios y bases de datos que poseen información de éste.

Un metadirectorio sirve precisamente para eso. Es un sistema de gestión de identidades que estaría «un nivel por encima» de los diferentes directorios, pues sirve para mantenerlos sincronizados y gobernarlos, aunque sin sustituirlos. Dispone de conectores con los diferentes directorios para propagar los cambios (políticas de información, atributos, perfiles de usuarios...) entre diferentes fuentes de información.

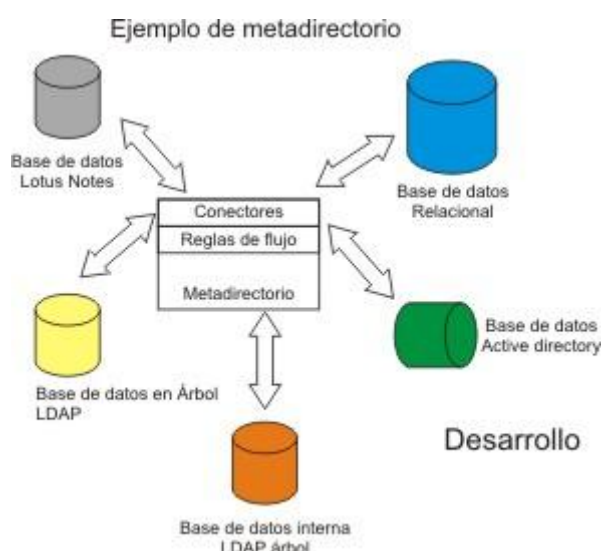


Imagen 1: Ejemplo de metadirectorio

Los metadirectorios como productos individuales (IBM Tivoli Directory Integrator, por ejemplo) alcanzaron su pico de popularidad en los años alrededor de 2010. Los departamentos TIC de muchas empresas se enfrentaban a este tipo de problemas cada vez que se producía una fusión corporativa o que una empresa compraba otra. Ello obligaba a integrar las redes internas, los sistemas de identidad y control de accesos, las aplicaciones, etc. Los departamentos TIC acudían a los metadirectorios para evitar los complejos proyectos de migración e integración.

Posteriormente, la aparición de la nube multiplicó los problemas relacionados con la identidad y el control de accesos incluso dentro de la propia empresa, como se expone en el siguiente capítulo, pero también cambió la forma de abordarlos y surgieron enfoques más modernos.

En la actualidad, aunque los metadirectorios pueden seguir estando soportados por los fabricantes y seguir en funcionamiento en algunas organizaciones, sus funciones están incluidas en muchos de los sistemas IAM modernos que se verán en el próximo capítulo.

Sistemas de provisión de usuarios

El software de aprovisionamiento de usuarios ayuda a las organizaciones a gestionar la información sobre los usuarios en varios sistemas y aplicaciones, implementando flujos de trabajo sobre un servicio de directorio.

Para entender el sentido de estos sistemas, podemos imaginar el procedimiento de alta de un nuevo usuario en una organización grande: probablemente alguien (quizás Recursos Humanos) tendrá que solicitar el alta, indicando la unidad en la que el empleado va a estar destinado. Lógicamente, el personal de RRHH no tiene acceso al servicio de directorio, que al ser uno de los servicios más críticos de la organización sólo unas pocas personas de IT pueden modificar. Será necesario por lo tanto un mecanismo para realizar esta solicitud, por ejemplo, un formulario o un correo electrónico. Quizás el personal de IT quiere realizar algunas comprobaciones, por ejemplo, con la unidad en la que va a estar destinado. Pueden hacerlo por teléfono, pero ¿no es más lógico hacerlo también mediante un formulario o un sistema informático? Sobre todo, si la organización tiene miles de empleados y cientos de unidades. Por otra parte, será necesario aprovisionar un ordenador y quizás un teléfono, que deben ser enrolados en los sistemas UEM de gestión de dispositivos y asociados al usuario. Y además será necesario concederle permisos en determinadas aplicaciones.

Todas estas actuaciones giran en torno al servicio de directorio, por lo que sólo el personal de IT puede realizarlas. En una organización con miles de empleados, supone una carga grande de trabajo.

Los sistemas de provisión de usuarios permiten:

- **Flujos de trabajo:** Las solicitudes de cambio presentadas por los usuarios para la creación de nuevos perfiles, la modificación o la desactivación de los mismos, deben de poder ser automatizadas, incluyendo la aprobación o rechazo con los diferentes responsables. La herramienta de aprovisionamiento permite la creación de estos flujos automatizados, con acciones como envío de correos, presentación de formularios, etc.
- **Delegación:** El sistema de aprovisionamiento de usuarios ofrece pantallas o formularios que no son los del servicio de directorio. Esto permite conceder permisos a los responsables de las unidades para que actúen como «administradores delegados» y gestionen a sus propios usuarios, a través de la herramienta de aprovisionamiento, pero sin tener acceso al servicio de directorio. Esto descarga de trabajo al equipo de IT y mejora la seguridad.
- **Autoservicio:** el propio usuario puede gestionar, por sí solo, situaciones como un cambio de contraseña, solicitud de permisos, etc.

Un ejemplo que combina dos de estas características sería un usuario que desea acceder a una unidad de red compartida. Sin un sistema de provisión de usuarios, tendría que solicitarlo al CAU para que el CAU a su vez lo solicite al administrador del servicio de directorio, que concedería el

permiso. Si es necesario recabar la autorización de la persona responsable de esa unidad de red, por ejemplo, una Subdirectora, entonces el CAU recabaría la autorización antes de enviar la petición al administrador del servicio de directorio.

Estos procesos, cuando hay miles de empleados en la organización, pueden consumir mucho tiempo y energía del departamento de IT.

Con un sistema como los aquí descritos, en cambio, el solicitante dispone de un formulario en el que puede indicar a qué unidad desea acceder. Un mensaje llega a la Subdirectora responsable (en nuestro ejemplo), que si así lo decide puede acceder a otro formulario y conceder el permiso. Como se ve, la petición no ha tenido que pasar ni por el CAU ni por el administrador del servicio de directorio, que pueden dedicar su tiempo a tareas más productivas.

Las soluciones de IAM más modernas, como las que se detallan en el apartado 5.5 de este tema, todas incorporan este tipo de funcionalidades. Sin embargo, los servicios de directorio tradicionales como Microsoft Active Directory no disponen de estas funcionalidades, por lo que es posible adquirir productos externos que se integran con AD para conseguirlas.

Algunos ejemplos son:

- Softerra Adaxes: Es una solución basada en Microsoft Active Directory, que permite automatizar y asegurar el aprovisionamiento de usuarios. Permite la automatización de tareas administrativas y la aprobación de flujo de trabajo basado en estándares de la organización, y garantiza altas prestaciones de gestión de ciclo de vida de la identidad de los usuarios.
- ManageEngine ADManager Plus, que integra tanto los flujos de trabajo para la gestión de permisos en AD como en Exchange y en Office 365 (misma problemática, con usuarios que abandonan la organización y cuentas *fantasma* que hay que desaproveccionar). Es una solución muy potente pero orientada únicamente a productos Microsoft.

3.2. Single Sign On (SSO)

En una organización que ha implantado un servicio de directorio, un usuario se encontraría con que tiene un único identificador de usuario y una única contraseña para acceder a todos los sistemas. Además, la organización puede establecer políticas con respecto a esa contraseña, como longitud y periodo de renovación obligatorio, y gestionar el alta y baja del usuario en un único punto.

Sin embargo, este hipotético usuario seguiría teniendo que teclear su contraseña una y otra vez, a medida que necesita acceder a diferentes recursos. Por supuesto que es más fácil que antes de implantar la gestión de la identidad, puesto que es siempre la misma contraseña (y no una diferente para cada recurso), pero sigue siendo una situación mejorable. En respuesta a esta situación surgió el concepto de Single Sign On.

El «*Single Sign On*», en español traducido como Inicio de Sesión Único, es el proceso mediante el cual un usuario sólo necesita autenticarse una vez en la organización y es capaz de acceder al

resto de servicios dentro del dominio de la organización. Por ejemplo, introduce su contraseña una única vez en su ordenador al iniciar sesión, y ya no necesita volver a introducirla después para acceder a la navegación web, a la impresora del pasillo o a otros servicios.

Los beneficios de implantar un sistema de SSO en la organización incluyen una mejor experiencia del usuario (usabilidad) y mayor seguridad, al no tener tanto riesgo de fatiga en la introducción de contraseñas.

Como inconveniente, los fallos del sistema de SSO (por ejemplo, un fallo de red) pueden llegar a negar el acceso a todos los sistemas unificados bajo el SSO.

Hablamos de SSO en un dominio cuando las diferentes aplicaciones tienen centralizado el proceso de autenticación. Es decir, el servidor de autenticación es común para todas las aplicaciones.

En la actualidad casi todas las organizaciones de tamaño medio o más grande tienen implantado SSO usando un servicio de directorio (a menudo Active Directory de Microsoft) para la gestión centralizada de identidades y permisos, y usan un protocolo de red para conseguir SSO en la mayoría de las aplicaciones. El protocolo más usado es *Kerberos*, que se integra muy bien con los servicios de directorio habituales.

Como se explicaba antes, la implantación de la identidad centralizada y el SSO son muy complejos y afectan a numerosas aplicaciones y sistemas. En la práctica, es raro que una organización consiga centralizar la gestión de la identidad y consiga además implementar el SSO al 100%. A menudo quedarán islotes de aplicaciones heredadas o de sistemas incompatibles que provocarán que haya puntos en los que el usuario tenga que volver a introducir sus credenciales. En los próximos apartados se detallan algunos casos en los que puede ocurrir esto. Idealmente, estos puntos de fricción deberían limitarse sólo a aquellos en los que sea inevitable, por la dificultad (o imposibilidad) de lograr su integración en el sistema IAM principal.

3.2.1. SSO usando Kerberos

Kerberos es un protocolo de red que proporciona servicios de autenticación y de autorización en un entorno de red de área local (LAN). Permite a dos computadores en una red insegura demostrarse su identidad mutuamente y de manera segura. Kerberos utiliza criptografía fuerte para la autenticación de un cliente ante un servidor. Una vez autenticado, se cifran todas las comunicaciones siguientes.

Kerberos evita enviar contraseñas como texto claro por una red, y permite centralizar tanto la identidad como la autenticación. Es posible usar Kerberos para implantar un sistema de SSO en la organización.

Kerberos fue inicialmente desarrollado por el MIT para proporcionar autenticación en un proyecto de computación distribuida en la universidad. Está disponible de forma gratuita, y también está implementado en muchos productos en el mercado. Se describe en la RFC 4120 de la Internet Engineering Task Force.

Funcionamiento del protocolo Kerberos

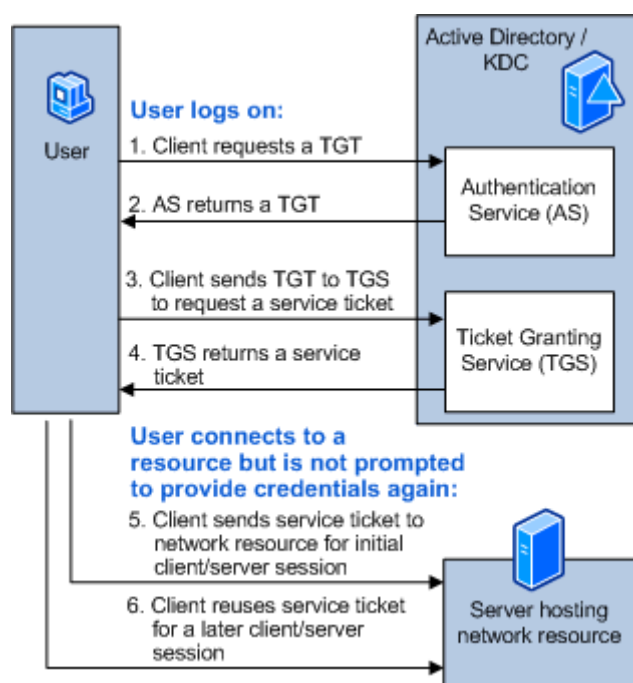
Kerberos se basa en criptografía de clave simétrica y requiere un tercero de confianza. Este tercero de confianza se denomina «centro de distribución de claves» (KDC, por sus siglas en inglés: *Key Distribution Center*), y consta de dos partes lógicas separadas: un «servidor de autenticación» (AS o *Authentication Server*) y un «servidor emisor de tickets» (TGS o *Ticket Granting Server*). Kerberos trabaja sobre la base de tickets, los cuales sirven para demostrar la identidad de los usuarios.

Kerberos mantiene una base de datos de claves secretas; cada entidad en la red —sea cliente o servidor— comparte una clave secreta conocida únicamente por él y Kerberos. El conocimiento de ésta sirve para probar la identidad de la entidad. Para una comunicación entre dos entidades, Kerberos genera una clave de sesión, la cual pueden usar para asegurar sus interacciones.

SSO basado en Kerberos

Kerberos, utilizado como sistema de SSO, consiste en que, una vez ha mostrado el usuario sus credenciales, obtiene un «ticket emisor de tickets» (TGT o *Ticket Granting Ticket*) del TGS. Otras aplicaciones del usuario adicionales que requieren autenticación (por ejemplo, clientes de correo, wikis, sistemas de control de revisiones, etc.) usan el TGT para adquirir «tickets de servicios» (TS o *Tickets Services*), que acreditan la identidad del usuario para dichas aplicaciones. En el SSO basado en Kerberos, el usuario (cliente) tiene un programa cliente en su ordenador que se ocupa de guardar los tickets y solicitarlos cuando el cliente vaya a acceder a un determinado servicio.

A continuación, se muestra una imagen de SSO utilizando el protocolo Kerberos, en un entorno Windows. En este caso, el Centro de Distribución de Claves (KDC) es el Directorio Activo. La aplicación, reconoce el método de autenticación con tickets de Kerberos, por lo que autenticará al usuario sin necesidad de que éste tenga que introducir sus credenciales.



El proceso de utilización de Kerberos con funcionalidad SSO es la siguiente:

1. El cliente se autentica y en el proceso de autenticación, el cliente solicita un Ticket Emisor de tickets (TGT).
2. El servicio de Autenticación, al comprobar que está autenticado, le proporciona un TGT al usuario.
3. El software cliente del usuario utiliza su TGT para conseguir un ticket válido para un servicio (por ejemplo, acceso al servidor de correo que se encuentra en el dominio de seguridad).
4. El servidor de autenticación le devuelve su ticket válido para acceder al correo.
5. El cliente solicita acceso al servidor de correo, enviando su TGS del correo.

Ejemplo práctico de SSO usando Kerberos

Muchas organizaciones usan Kerberos en su día a día para la autenticación de los empleados y el control de accesos. Consideremos un ejemplo de uso de Kerberos en un entorno corporativo, cuya protagonista se llama Rebeca.

Rebeca accede a la red corporativa a través de su portátil corporativo, introduciendo un nombre de usuaria y una contraseña. El sistema operativo de su portátil envía en ese momento su identificador de usuaria al servicio de directorio, que en nuestro ejemplo sería un servidor de Microsoft Active Directory. Este servicio de directorio desempeña el papel de KDC de Kerberos, como se ha visto anteriormente. Este envío es transparente para Rebeca; ella no sabe que se ha producido.

El KDC devuelve un TGT cifrado con la clave secreta de Rebeca almacenada en el KDC. Si la clave secreta coincide en el portátil y en el KDC, el portátil podrá descifrar el TGT y permitirá a Rebeca acceso al portátil (inicio de sesión). El sistema operativo del portátil almacena a partir de ese momento el TGT, durante toda la sesión de usuaria.

Más tarde ese mismo día, Rebeca tiene que imprimir un documento. El sistema operativo envía el TGT al TGS en el KDC. El TGS crea una clave de sesión para la impresora, y se la devuelve al sistema operativo del portátil de Rebeca. En realidad, lo que hace es generar un ticket que contiene la clave de sesión cifrada con la clave secreta de Rebeca y otra clave de sesión cifrada con la clave secreta del servidor de impresión, y es ese ticket lo que envía al portátil.

El portátil de Rebeca recibe este ticket y lo descifra usando la clave secreta de Rebeca. A continuación, elimina la clave de sesión, añade un segundo autenticador, y lo envía al servidor de impresión. El servidor de impresión recibe este ticket y lo descifra con su clave secreta. Si es capaz de descifrar la clave de sesión sabe que puede confiar en el ticket y en Rebeca, porque sabe que el ticket lo ha creado el KDC.

Lo más interesante de todo esto es que Rebeca ni siquiera se da cuenta de que todos estos intercambios están teniendo lugar. Lo gestionan el sistema operativo de su portátil, el servicio de directorio (es decir, el KDC) y el servidor de impresión. Lo único que hizo Rebeca fue introducir su nombre de usuaria y su contraseña al iniciar sesión en el portátil.

3.2.2. SSO Web usando cookies

Una de las limitaciones del SSO con el protocolo Kerberos es que no es compatible con las aplicaciones web a las que se accede a través del navegador. Sencillamente, el protocolo que se ha descrito en el apartado anterior no es compatible con el acceso web a una aplicación.

En este apartado se describe una técnica para conseguir el SSO en aplicaciones Web accesibles a través del navegador. Pero es importante destacar que esta técnica *sólo funciona cuando todas las aplicaciones web se encuentran dentro de un único dominio de seguridad*.

Esto es así porque, por evidentes razones de seguridad, los navegadores almacenan las cookies de cada dominio por separado, y no permiten utilizar las cookies de un dominio en otro.

Este sistema se utiliza dentro de un dominio, y tiene sentido cuando existen múltiples aplicaciones web en el mismo dominio. Ejemplos muy frecuentes son:

- el acceso a diferentes aplicaciones corporativas disponibles en la Intranet. Por ejemplo, una organización podría poner varios servicios al empleado en su Intranet, tales como la aplicación de fichaje y control horario, la de vacaciones, la de reserva de salas de reuniones, la de registro de invitados, la de consulta de nóminas, etc. Una vez que el empleado accede por primera vez a una de ellas, ya no necesita volver a autenticarse para acceder a las demás;
- el acceso a diferentes aplicaciones de un gran proveedor de servicios online. Por ejemplo, imaginemos un proveedor de correo que también ofrece una suite de ofimática online, calendario y un servicio de llamadas y videoconferencia desde el navegador. Para evitar que los usuarios tengan que autenticarse cada vez que acceden a una de estas aplicaciones, puede implementar el SSO web basado en cookies. Así, si el usuario se ha autenticado para acceder a su correo y posteriormente quiere editar una hoja de cálculo, no es necesario pedirle que vuelva a autenticarse.

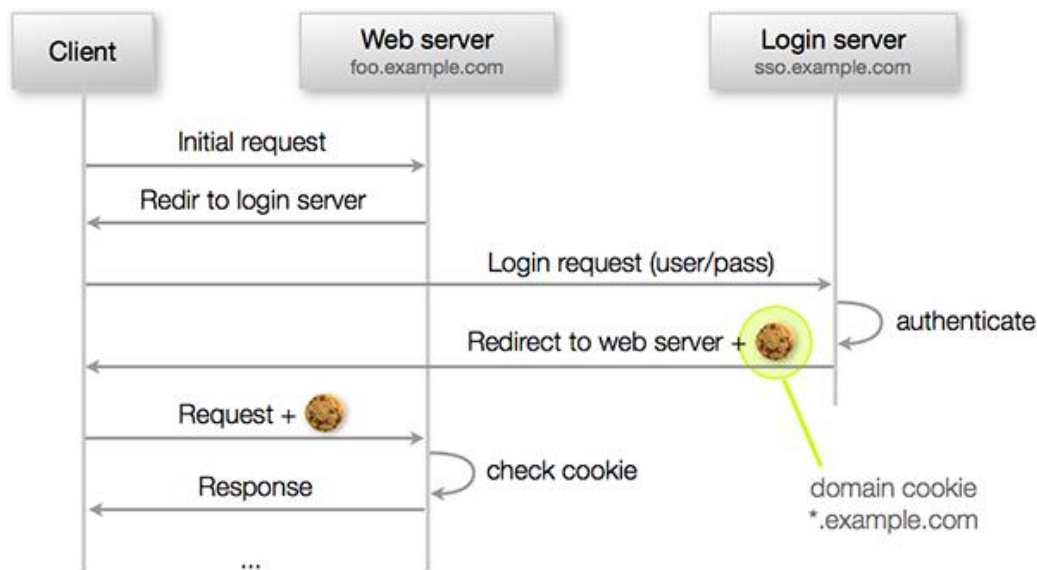


Imagen 3: Web SSO dentro de un dominio

En la imagen, se muestra un diagrama de secuencia que presenta cómo se realiza Web SSO dentro del dominio. El dominio en el que se está realizando SSO es *example.com*. Dentro de dicho dominio, existen varias aplicaciones que lo usan, en la presente figura son dos aplicaciones: *foo.example.com* y *sso.example.com*.

Las peticiones del cliente son http o https y se realizan desde un navegador. El proceso que tiene lugar es el siguiente:

1. *Initial request*: El navegador intenta acceder a una página *foo.example.com* a través de una petición http.
2. *Redir to login Server*: El servidor web *foo.example.com* comprueba que dicho usuario no está autenticado, por lo que solicita un http redirect para redirigir al usuario al servicio de autenticación.
3. *Login request*: El servicio de autenticación solicita al usuario que presente sus credenciales y el usuario se autentifica.
4. *Redirect to web Server + cookie*: Una vez autenticado, el servidor de autenticación le envía una petición HTTP redirect y le añade una cookie de sesión.
5. *Request + cookie*: El navegador del usuario presenta una petición http y lleva incrustada la cookie de sesión.
6. *Response*: El servidor *foo.example.com* comprueba que la cookie de sesión es válida y no ha expirado, por lo que presenta su información al usuario.

Obsérvese que, en una organización típica, por ejemplo, en el escenario de servicios accesibles a través de una Intranet corporativa, lo más normal es que el Login Server sea el servicio de directorio (típicamente, Microsoft Active Directory) ya implantado.

Ejemplo práctico de SSO Web

Retomando el ejemplo práctico del apartado anterior, podríamos suponer que la misma organización ha implantado SSO web en su Intranet. En este caso, la usuaria Rebeca está acostumbrada a acceder al servidor de impresión de manera transparente usando Kerberos, y sabe que no tiene que introducir su contraseña cuando va a imprimir. Simplemente, «todo funciona».

En cambio, si tras iniciar sesión en su equipo necesita acceder a algún servicio de la Intranet, sabe que la primera vez tiene que introducir su nombre de usuaria y su contraseña de nuevo. No le resulta complicado porque es el mismo identificador y la misma contraseña, ya que al fin y al cabo provienen del mismo servicio de directorio. Además, sólo tiene que hacerlo una vez, la primera. A partir de ese momento su navegador almacenará la cookie (igual que el sistema operativo almacena el TGT Kerberos) y ya no tendrá que autenticarse para acceder a otras aplicaciones de la Intranet en la misma sesión.

En cambio, si más tarde tiene que acceder al CRM online (en modalidad SaaS) que utiliza la empresa, y que lógicamente está en otro dominio diferente al de su organización, tendrá que volver a introducir su contraseña. Probablemente el proveedor del CRM en la nube permitirá la integración del mismo con el servicio de directorio local, por lo que Rebeca seguirá teniendo la misma identidad y contraseña, pero aun así tendrá que introducirla de nuevo.

4. Acceso remoto a sistemas corporativos

El capítulo anterior describe los sistemas IAM más frecuentes en el entorno que hemos denominado «tradicional». Este entorno consiste en un dominio o varios dentro de una red de área local.

Se denomina «acceso remoto» al conjunto de sistemas que permiten a un empleado acceder a la red corporativa desde fuera de la misma. Por ejemplo, un empleado que utiliza un portátil corporativo para conectarse desde un aeropuerto a la red de área local de la empresa y acceder a sus aplicaciones y recursos, que sólo están disponibles dentro de dicha red interna.

La identificación, autenticación y autorización es un componente fundamental de la implantación del acceso remoto en una organización. A diferencia de las soluciones IAM que se explican en el capítulo anterior, las soluciones para el acceso remoto tienen que estar disponibles y abiertas en Internet. Ello aumenta considerablemente el riesgo.

4.1. Acceso remoto usando RADIUS

RADIUS (Remote Authentication Dial In User Service) es un protocolo cliente-servidor que proporciona autenticación y autorización para usuarios remotos. También proporciona capacidad de auditoría, por lo que es un protocolo AAA. RADIUS se define en la RFC 2865 y la capacidad de auditoría se define por separado (por lo que su uso es opcional) en la RFC 2866.

Los identificadores de los usuarios y sus contraseñas se almacenan en un servicio de directorio en la red de área local. Es decir, RADIUS se utiliza en conjunto con un servicio de directorio. El servicio de directorio proporciona la información sobre identidad y las autorizaciones (roles) del usuario, y puede proporcionar la contraseña, pero la autenticación se realiza mediante el protocolo RADIUS.

RADIUS requiere el uso de un Network Access Server (NAS) y un Servidor de Autenticación (que normalmente será el servicio de directorio). Funciona sobre una red IP, usando paquetes UDP.

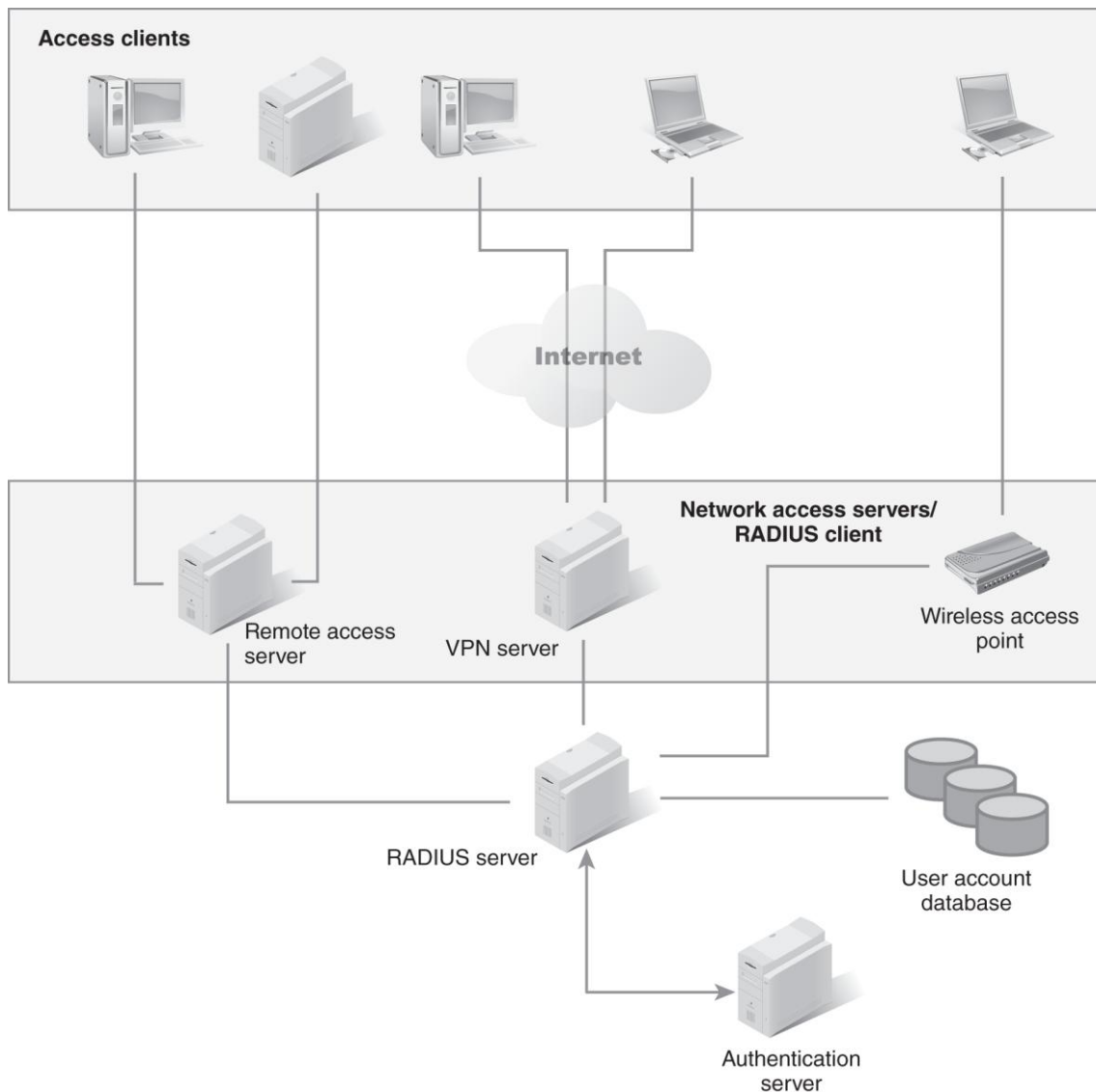


Imagen 4: Ejemplo de despliegue de un servidor RADIUS

El protocolo RADIUS funciona de la siguiente manera:

1. El usuario se conecta a un cliente RADIUS, como por ejemplo un servidor de VPN, NAS o un servidor de acceso remoto, y proporciona sus credenciales (identificador de usuario y contraseña). La contraseña se sustituye por un hash para evitar que viaje por la red.
2. El cliente RADIUS envía la solicitud de acceso al servidor RADIUS.
3. Cuando el servidor RADIUS recibe la solicitud, autentica al cliente RADIUS (no los datos del usuario, sino los del cliente RADIUS) a través de un secreto compartido. Si no conoce al cliente o no dispone del secreto compartido, descarta la solicitud.
4. Tras autenticar al cliente RADIUS, el servidor RADIUS revisa la base de datos de usuarios. Típicamente en este punto lo que hace es conectarse a un servicio de directorio a través

del protocolo LDAP. El servicio de directorio confirma la identidad y puede aportar condiciones que se deben cumplir para permitir el acceso. Estas condiciones pueden referirse a la autenticación, pero también determinar los puertos a los que el cliente puede tener acceso.

5. En función de la respuesta del servicio de directorio, el servidor RADIUS puede responder al cliente con un desafío. Un ejemplo de desafío puede ser un SMS que el usuario debe introducir en el cliente.
6. Cuando el usuario proporciona la respuesta al desafío al cliente, éste vuelve a enviar la solicitud de acceso original con un nuevo identificador y la respuesta al desafío cifrada. La respuesta ocupa el mismo lugar en esta nueva solicitud que ocupaban en la anterior el identificador de usuario y la contraseña.
7. El servidor RADIUS puede responder a la nueva solicitud con una aceptación del acceso, una denegación de acceso o con un nuevo desafío.
8. Eventualmente, si el usuario supera todos los desafíos y se cumplen todas las condiciones, el servidor RADIUS emitirá una respuesta de aceptación del acceso. Esta aceptación incluye el tipo de conexión permitida y otros valores necesarios para establecerla, como valores de TCP/IP o de Point-to-Point Protocol.

Una de las grandes ventajas del protocolo RADIUS, por lo tanto, es que permite la emisión de desafíos al cliente. Eso es fundamental para permitir la autenticación multifactor, y es algo de lo que carece el protocolo Kerberos.

Los servidores de VPN utilizan frecuentemente RADIUS para permitir la autenticación multifactor de los usuarios, conectado a su vez a un servicio de directorio en el que se almacenan realmente los datos de los usuarios y sus autorizaciones (roles).

Una debilidad importante de RADIUS es que sólo cifra la contraseña del usuario. No cifra la totalidad del paquete de datos.

4.2. Acceso remoto usando TACACS+

TACACS (Terminal Access Controller Access Control Server) es un protocolo cliente-servidor que permite la autenticación. Se utiliza en muchos equipos de red, tales como routers o switches. TACACS combina la autenticación y la autorización usando TCP/IP o UDP/IP.

TACACS no es un estándar de Internet. Se describe en la RFC 1492 con fines informativos únicamente. No es un protocolo seguro porque envía los identificadores de usuario y las contraseñas como texto claro, y por eso no se usa actualmente.

XTACACS (Extended TACACS) es un protocolo cliente-servidor basado en TACACS. Mejora TACACS porque separa la autenticación, la autorización y la auditoría (los logs de autenticación y autorización), proporcionando AAA. Lo desarrolló Cisco en los años 90, pero tampoco se usa actualmente por razones de seguridad.

TACACS+ también es un protocolo propietario de Cisco, basado en XTACACS. Lo mejora porque sí cifra las comunicaciones. Se utiliza para la autenticación en routers, servidores de acceso a la red y otros equipos de red.

TACACS+ es un protocolo más seguro que RADIUS porque cifra la totalidad del paquete, no sólo la contraseña del usuario.

4.3. Acceso remoto usando PAP

PAP (Password Authentication Protocol) es un protocolo en la capa OSI de enlace que proporciona autenticación sobre PPP (Point-to-Point Protocol). PPP permite enviar tráfico TCP/IP sobre una línea telefónica. PAP transmite el usuario y la contraseña en claro, por lo que se considera altamente inseguro.

CHAP (Challenge Handshake Authentication Protocol) está definido en la RFC 1994. Proporciona autenticación sobre PPP usando un *3-way handshake*. CHAP sí se considera seguro en la actualidad.

MS-CHAP es la versión de Microsoft del protocolo CHAP. Sólo se usa en entornos exclusivamente Microsoft y utiliza cifrado DES (Data Encryption Standard), que en la actualidad se considera inseguro y no se debería usar, salvo que se envuelva en otro cifrado más potente.

Ninguno de estos tres protocolos se usa en la actualidad, ya que se basan en PPP. Es posible encontrarlos en sistemas antiguos heredados. No se deben valorar como una opción realista para la implantación de sistemas modernos de acceso remoto. No obstante, CHAP sí es un protocolo de autenticación para el acceso remoto que se puede considerar seguro.

5. IAM en el entorno corporativo moderno (nube)

Las configuraciones típicas de SSO presentadas en los capítulos anteriores tenían una premisa común: todos los procesos se ejecutaban dentro de un solo dominio. Cada dominio normalmente cuenta con una infraestructura de seguridad y un conjunto de servicios de aplicación que se administran dentro de una autoridad común que coordina la política intra-dominio. Esto es lo que hemos denominado, en este tema, un entorno «tradicional».

Esta situación empezó a cambiar en la primera década de los años 2000, con la aparición de los «servicios en la nube». Por ejemplo, Salesforce se fundó en 1999 y realizó su oferta pública inicial en 2004. En el año 2009 alcanzó por primera vez 1.000 millones de dólares de ingresos. ServiceNow se fundó en 2004. AWS se lanzó por primera vez en 2006, y en el año 2007 Netflix empezó su servicio de vídeo bajo demanda apoyándose en la infraestructura de AWS.

A medida que las organizaciones públicas y privadas empiezan a adoptar la nube, en la segunda década de este siglo, sus departamentos TIC se van dando cuenta de que los modelos IAM que utilizan son insuficientes.

Esto se debe a que los productos de IAM basados en un servicio de directorio local, Kerberos para el SSO en la red local y RADIUS o TACACS+ para la autenticación de los usuarios remotos están totalmente orientados al acceso a aplicaciones alojadas en la red local de la organización. No sirven (o sirven con mucha dificultad y limitaciones) para aplicaciones alojadas por terceros en CPDs que no controla la organización, es decir, para la nube.

Afortunadamente, en el año 2005 se había publicado un nuevo estándar de la industria, SAML 2 (Security Assertion Markup Language). SAML 2 solucionaba la cuestión del SSO Web entre dominios diferentes, sentando las bases de lo que se denomina «federación de identidades». Aunque inicialmente se diseñó pensando en los clientes de una organización, enseguida se vio que también se adaptaba muy bien para su uso por parte de los empleados.

Es por lo tanto en torno a finales de esta década cuando empiezan a surgir nuevas herramientas, basadas en SAML y otras tecnologías similares, diferentes al modelo «tradicional», en el cual todas las aplicaciones se encontraban dentro de un mismo dominio de seguridad. Estas nuevas herramientas se adaptan mucho mejor al modelo de nube híbrida y multinube, que empieza a ser el predominante en la mayoría de organizaciones.

Por ejemplo, Okta fue fundada en 2009 y realizó su oferta pública inicial en 2017. ForgeRock se fundó en Noruega en 2010. Ping Identity fue fundada en 2002 pero disparó su crecimiento a partir de 2011. Aunque se detallará más adelante en este capítulo, se puede ver que la fundación o el crecimiento de estas empresas se produce en los años alrededor de 2010.

Las soluciones más modernas de IAM dan respuesta a la aparición de la nube, a la explosión en el uso de servicios SaaS y a los desafíos que esto plantea. No sustituyen necesariamente las soluciones ya existentes en la red local para el acceso a servidores de impresión o a unidades de red compartidas.

5.1. Características y capacidades de las soluciones IAM modernas

Las soluciones modernas proporcionan las siguientes capacidades:

- se ofrecen como servicio en la nube (SaaS). A menudo no es posible instalarlas en la infraestructura local;
- ofrecen las funcionalidades de un servicio de directorio, es decir, funcionan como base de datos de usuarios y de recursos, permitiendo definir roles y otras reglas relativas a la autorización;
- autenticación de los usuarios, multifactor en su caso;
- ofrecen capacidades conocidas como «federación de identidades», mediante tecnologías tales como SAML, OAuth2, WS-Fed u OpenID Connect, y que permiten a un usuario acceder a aplicaciones web en diferentes dominios (por ejemplo, Salesforce y ServiceNow) con una única identidad gestionada por su organización de manera centralizada;
- gestión de los accesos internos: flujos de actividad para el onboarding de usuarios, la gestión de contraseñas y la gestión de roles;
- gestión de los accesos externos: flujos de actividad que permiten el registro de usuarios externos a la organización (clientes, proveedores...), la gestión de sus perfiles, la administración delegada de permisos y usuarios, integración que permite BYOI (Bring Your Own Identity) y gestión de consentimiento para tratamientos de datos, entre otras;
- control de accesos adaptativo;
- control de acceso a APIs.

5.2. Federación de identidades

La federación de identidades es la función principal de las aplicaciones IAM modernas.

Se denomina Federación de Identidades al conjunto de tecnologías, normas y casos de uso que permiten intercambiar información sobre identidad de usuarios en diferentes dominios de seguridad. El principal propósito de la federación de identidades es permitir a los usuarios de un dominio que puedan acceder de forma segura a los datos o sistemas de otro dominio sin problemas, realizando la administración de usuarios en un único punto.

Componentes de la federación de identidades

En una solución de identidad federada, se pueden identificar los siguientes componentes:

- Proveedor de Identidad (*Identity Provider*, IdP): Una entidad que dispone de la infraestructura necesaria para la autenticación de usuarios.
- Proveedor de Servicios (*Service Provider*, SP): Es una entidad que da acceso al usuario a un recurso o aplicación.

- Círculo de Confianza (*Circle of Trust*): Un círculo de confianza es un conjunto de entidades (compañías, departamentos, admones. públicas, etc.) que han firmado un acuerdo de negocio para suministrar una serie de servicios a sus usuarios comunes, basado en una relación de confianza entre ellos, es decir, es un entorno de seguridad multi-dominio en donde se pueden compartir servicios a unos usuarios. Para ofrecer federación de identidades es necesario que se establezca el círculo de confianza (dominios de seguridad que confían los unos en los otros) junto con los correspondientes acuerdos de servicio.

Dentro de un dominio sólo habrá un Proveedor de Identidad, aunque sí es posible que haya diversos Proveedores de Servicio SP. En un círculo de confianza, pueden coexistir varios proveedores de servicios, así como varios proveedores de identidad.

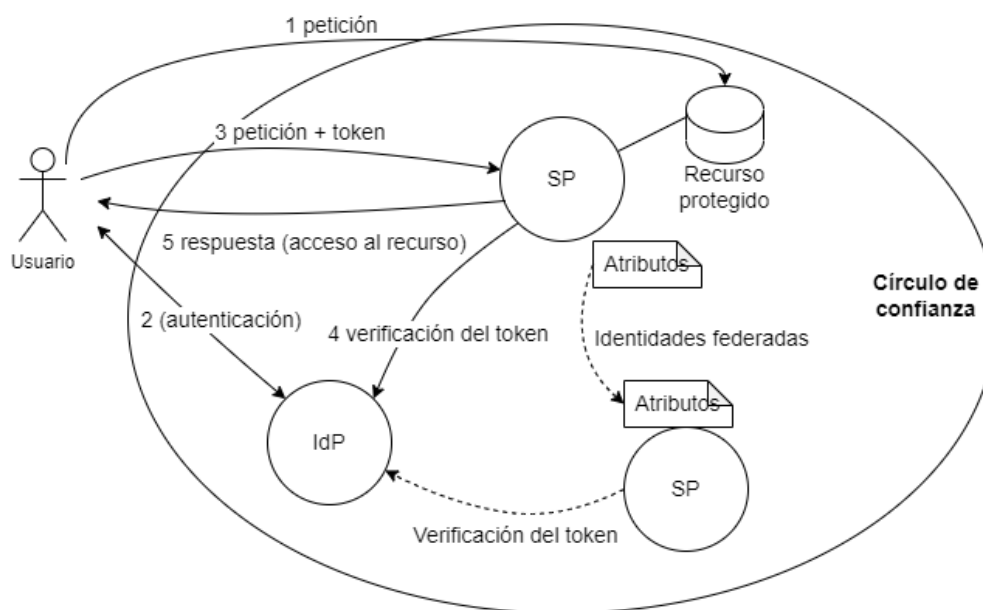


Imagen 5: Círculo de confianza con Proveedores de Identidad (IdP) y Proveedores de Servicios (SP).

Dentro de un dominio sólo habrá un Proveedor de Identidad, aunque es posible que haya diversos Proveedores de Servicio SP. En un círculo de confianza, pueden coexistir varios proveedores de servicios, así como varios proveedores de identidad.

5.3. SAML 2

SAML (*Security Assertion Markup Language*) es un estándar abierto basado en XML desarrollado por el *Security Services Technical Committee* (SSTC) de la *Organization for the Advancement of Structured Information Standards* (OASIS). Actualmente se encuentra en su versión 2.0.

El caso de uso para el que SAML 2 se usa más habitualmente es el SSO entre distintos dominios.

En este escenario, un usuario tiene que utilizar aplicaciones web en diferentes dominios en Internet, tales como *aplicacion1.com* y *aplicacion2.com*. Sin SSO entre dominios, el usuario tendría que crear una cuenta y una contraseña en cada una de las aplicaciones, y acceder a cada una de manera individualmente.

Como consumidores individuales, a menudo esto es lo que ocurre entre las diferentes aplicaciones que utilizamos. Por ejemplo, tenemos una cuenta en una tienda online, otra cuenta en otra, otra cuenta diferente en un sitio de streaming de series, y otra en la aplicación web del gimnasio, por poner algunos ejemplos.

Sin embargo, esto puede suponer un problema para una organización. Imaginemos que esa organización utiliza diferentes herramientas en modalidad SaaS: por ejemplo, la solución ITSM, la aplicación de contabilidad y el CRM son soluciones SaaS. La organización desearía, lógicamente, centralizar todas las identidades en un único directorio, a fin de poder tomar medidas tales como facilitar las altas y bajas de los empleados, imponer políticas de seguridad sobre la autenticación (longitud de contraseñas, múltiples factores...), etc.

Las aplicaciones que implementan SAML 2 delegan la autenticación de sus usuarios a un sistema remoto conocido como «proveedor de identidad» (identity provider). Es decir, en el ejemplo anterior, la organización deberá comprobar si las aplicaciones SaaS que tiene contratadas soportan la autenticación con SAML 2, y sólo podrá utilizarlo para ofrecer SSO a sus empleados si la respuesta es afirmativa.

SAML 2 también proporciona un mecanismo para que una aplicación y un proveedor de identidad utilicen un identificador común del usuario, conocido por ambos, en lugar del nombre real del usuario. Esto es lo que se conoce como «identidad federada». La identidad federada puede usar el mismo identificador entre varios dominios, o utilizar uno diferente en cada dominio.

Funcionamiento de SAML 2

El escenario más habitual para usar SAML 2 es el de un usuario que desea acceder a una aplicación. La aplicación, en términos de SAML, es el *proveedor de servicio*, en inglés *service provider*. Proporciona el servicio que el usuario desea utilizar, como por ejemplo el CRM, la contabilidad o el ITSM.

El proveedor de servicios, sin embargo, no autentica al usuario. En su lugar, delega la autenticación a un *proveedor de identidad*, que puede encontrarse en un dominio diferente. Es el proveedor de identidad quien autentica al usuario, y devuelve luego un token de seguridad, que es la denominada *SAML assertion*, es decir, una *afirmación SAML*. Esta afirmación SAML contiene información sobre la identidad del usuario y el evento de la autenticación.

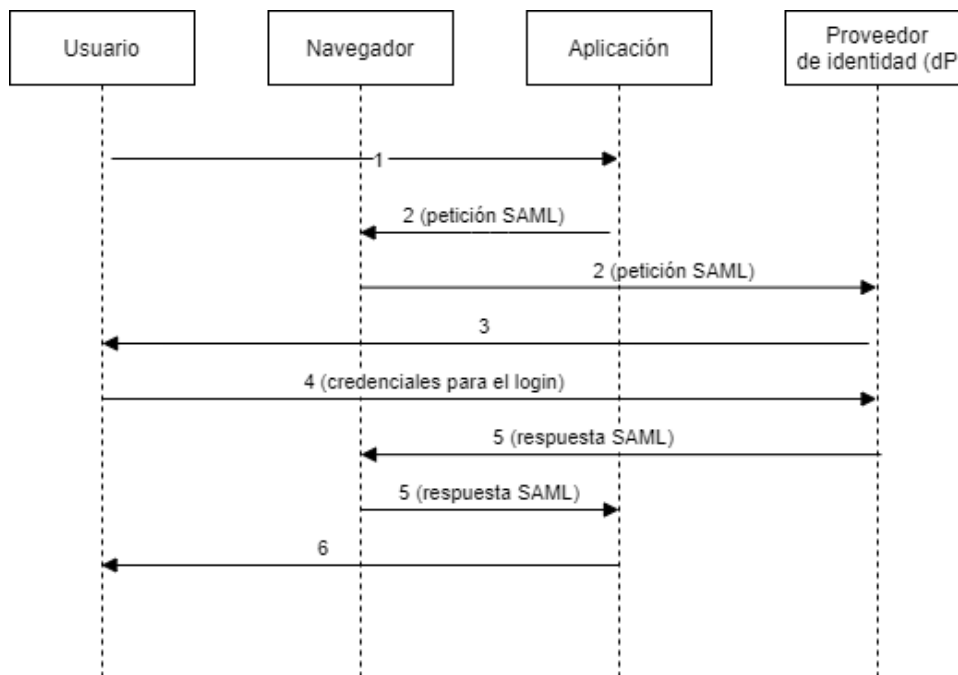


Imagen 6: Diagrama de secuencia de una autenticación usando SAML 2.

1. El usuario visita una aplicación web, es decir, un proveedor de servicios. Normalmente esta aplicación web dispondrá de una pantalla de *login* (acceso), en la que el usuario pulsa.
2. El proveedor de servicios redirige el navegador del usuario al proveedor de identidad.
3. El proveedor de identidad solicita al usuario su identificación y su autenticación.
4. El usuario proporciona los datos de su identidad y se autentica.
5. El proveedor de identidad redirige el navegador del usuario de vuelta al proveedor de servicios, esta vez con una respuesta SAML que contiene una aserción SAML.
6. El proveedor de servicios verifica la aserción SAML y, si es correcta, por fin entrega al usuario la página que este deseaba visitar.

El proceso anterior corresponde a la autenticación con una única aplicación. Si varias aplicaciones utilizan el mismo proveedor de identidad, entonces la misma aserción SAML sirve para todas ellas. Esto permite el SSO entre todas estas aplicaciones.

La especificación define la estructura y el contenido de cuatro elementos principales:

- **Assertions:** Las aserciones son paquetes XML que contienen información de identidad, autenticación y autorización sobre un sujeto determinado. Se definen mediante un Esquema XML y pueden ser enviadas de forma directa o expedirse como consecuencia

de una solicitud. Una aserción SAML puede transportar en su interior tres tipos de *statements* (declaraciones):

- *Authentication statements*: son expedidas por la entidad que ha llevado a cabo el proceso de autenticación del usuario. En una declaración de este tipo se recoge quién la ha emitido, el sujeto autenticado, el período de validez de la misma, además de otros datos relacionados con la autenticación.
 - *Attribute statements*: contienen detalles específicos sobre el usuario, nombre, dirección de email, rol, grupo al que pertenece, etc.
 - *Authorization statements*: recogen datos sobre lo que le está o no permitido hacer al usuario. Por ejemplo, si está o no autorizado a acceder a un determinado recurso.
- **Protocols**: Los protocolos definen las peticiones de las *assertions* y las respuestas de las mismas. Poseen su propio Esquema XML. Algunos de los protocolos son los siguientes:
 - *Authentication Request Protocol*: Define un mensaje <AuthRequest> que provoca como respuesta uno del tipo <Response>, el cual contiene una o más *assertions*, relativas a un determinado sujeto. Generalmente, la solicitud es emitida por un Proveedor de Servicios y contestada por un Proveedor de Identidad tras haber completado con éxito un proceso de autenticación del usuario.
 - *Assertion Query and Request Protocol*: Se definen una serie de métodos para obtener aserciones SAML ya existentes. Pueden solicitarse facilitando a un Proveedor de Identidad una referencia a dicha aserción, como el identificador único de aserción, mediante el uso del elemento <AssertionIDRequest>. Otros ejemplos incluyen el elemento <AttributeQuery>, mediante el cual se piden los valores de determinados atributos del usuario.
 - Existen otros protocolos como el SAML Artifact Protocol, que proporciona un mecanismo mediante el cual los mensajes del protocolo SAML pueden ser transportados por referencia en lugar de por valor, el SAML *Name Identifier Mapping Protocol*, que permite el «enlace de cuentas de un mismo usuario» y SAML *Single Logout Protocol* para permitir el cuasi cierre de todas las sesiones abiertas en los diferentes SPs pertenecientes a un mismo usuario
 - **Bindings**: Los bindings especifican cómo los mensajes de los protocolos SAML pueden transportarse utilizando protocolos de más bajo nivel, tal como HTTP o SOAP.
 - **Profiles**: Los protocolos, *bindings* y aserciones de SAML se combinan para formar perfiles. Un perfil puede ser considerado como el conjunto de elementos e interacciones entre ellos que son necesarios para satisfacer un caso concreto de utilización de SAML. Algunos de los perfiles que se definen son:
 - **Web Browser SSO Profile**: Especifica cómo se puede proporcionar un servicio de SSO mediante un navegador web, utilizando para ello mensajes del

Authentication Request Protocol en combinación con los *bindings* HTTP Redirect, HTTP POST y HTTP Artifact.

- **Assertion Query/Request Profile:** Define cómo el protocolo SAML del mismo nombre hace uso del SAML SOAP Binding.
- **Artifact Resolution Profile:** Define cómo el Artifact Protocol utiliza el SOAP Binding
- **Identity Provider Discovery Profile:** Define los medios para que un Proveedor de Servicios descubra qué Proveedor(es) de Identidad está utilizando un determinado usuario.

La seguridad en SAML

SAML está diseñado para integrarse con **XML Encryption** y **XML Signature**, estándares cuya finalidad es incrustar información cifrada y firmas digitales, respectivamente, en un documento XML. XML Signature se utiliza en SAML para proveer autenticación, es decir, determinar la identidad de la otra parte (dominio) en una transacción, así como la integridad de datos, esto es, la capacidad para confirmar que el mensaje recibido no presenta alteraciones con respecto al transmitido.

XML Encryption proporciona confidencialidad, de forma que, de todas las posibles entidades por las que el mensaje pueda pasar, sólo los destinatarios originales podrán leer el contenido cifrado que contenga.

5.4. OAuth 2 y OpenID Connect

OAuth 2

En este capítulo, usaremos el término OAuth 2 para referirnos indistintamente al OAuth Authorization Framework en sus versiones 2.0 y 2.1. OAuth 2.0 se publicó en 2012, y empezó a revisarse en 2020 (la versión OAuth 2.1 todavía está en desarrollo).

El diseño de las aplicaciones modernas, en general, está centrado en las APIs. En general, las APIs tienen que restringir el acceso a su funcionalidad sólo a los sujetos autorizados. Es probable que una aplicación que quiere usar una API necesite autorización para hacerlo. Si la aplicación quiere acceder en nombre de su usuario a recursos gestionados por una API, necesita el permiso del usuario. Pero si el usuario facilita su nombre de usuario y contraseña a la aplicación, le está proporcionando una información muy valiosa. Por no hablar de la responsabilidad de la aplicación, que tiene que almacenar esa contraseña de manera segura.

En el pasado, esto se hacía así (y todavía hoy muchas aplicaciones lo hacen así). Sin embargo, OAuth 2 proporciona una solución mejor para permitir a las aplicaciones invocar APIs en nombre del usuario de la aplicación.

Con OAuth 2, una aplicación puede obtener el permiso de un usuario para invocar una API en nombre de dicho usuario y acceder al contenido de dicho usuario custodiado por la API. Por supuesto, la aplicación también puede invocar la API por sí misma (no en nombre de un usuario) si es la propietaria del contenido al que quiere acceder.

El usuario de la aplicación, que también es el dueño del recurso custodiado por la API, se llama el «propietario del recurso» (resource owner). La API se denomina el «servidor de recursos» (resource server). El propietario de los recursos ha almacenado recursos (contenidos) en el servidor de recursos.

Si no estuviera usando OAuth 2, el propietario del recurso tendría que dar a la aplicación su nombre de usuario y su contraseña para que pudiera acceder a los recursos. Esto no está exento de riesgos, pues la aplicación puede actuar en el servidor de recursos como si fuera el propio usuario.

Por ejemplo, imaginemos que el usuario ha instalado una aplicación *fintech* que analiza sus gastos y le propone consejos para ahorrar. Para que la aplicación pueda analizar sus gastos, el usuario tiene que introducir la información de las cuentas bancarias y las tarjetas que utiliza, y si no se está usando OAuth, tendría que introducir en la aplicación el nombre de usuario y la contraseña de cada una de las cuentas y tarjetas. Con eso, la aplicación puede consultar todos sus gastos y elaborar su análisis. Pero claro, también puede hacer cualquier otra acción que desee. El usuario haría bien en desconfiar de esta aplicación. Incluso si la aplicación es legítima y actúa de buena fe, es posible que muchos usuarios desconfiaran y se negaran a utilizarla (con razón).

OAuth 2 proporciona una solución mejor. Con OAuth 2, existe un «servidor de autorizaciones», *authorization server*, para la API. La aplicación realiza una solicitud de acceso a este servidor, y si todo es correcto, éste devuelve un token seguro que la aplicación puede utilizar para acceder al servidor de recursos.

Es importante destacar que OAuth 2 proporciona una solución de autorización (control de accesos), pero no de autenticación. El usuario tiene que autenticarse, pero lo único que se valida es su identidad y que tenga permiso para autorizar a la aplicación a acceder al recurso solicitado. El token que se intercambia es un token de autorización *para el acceso a un recurso*, y no está diseñado para contener información sobre el usuario ni sobre el evento de la autenticación. Por ello el uso de OAuth 2 es apropiado para autorizar llamadas a APIs, pero no para la autenticación del usuario.

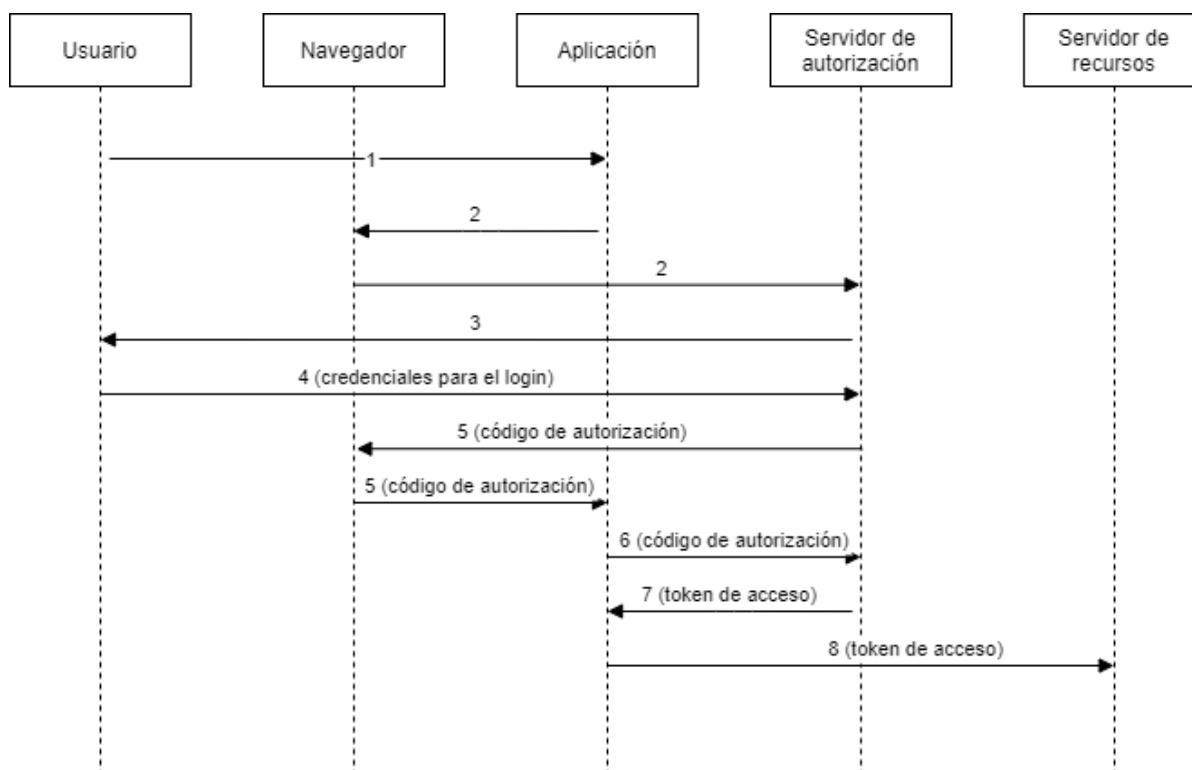


Imagen 7: Diagrama de secuencia de una autorización usando OAuth 2.

1. El usuario (el propietario del recurso) accede a la aplicación.
2. La aplicación redirige el navegador al servidor de autorización, con una solicitud de autorización.
3. El servidor de autorización solicita al usuario tanto su autenticación como su consentimiento.
4. El usuario se autentica y proporciona el consentimiento para la solicitud.
5. El servidor de autorización redirige el navegador de vuelta a la URL llamante de la aplicación, con un código de autorización.
6. La aplicación envía este código de autorización al servidor de autorización.
7. El servidor de autorización responde a la aplicación enviándole un token de acceso.
8. La aplicación llama al servidor de recursos (la API que el usuario quiere utilizar) usando este token de acceso.

En resumen, OAuth permite conceder acceso a un recurso garantizando la confidencialidad del cliente que solicita dicho acceso. Esto se consigue gracias al servidor de autorizaciones.

Se usan diferentes tipos de tokens de acceso. Algunos servidores de autenticación emiten un token «opaco», que es una cadena de texto cifrada. Otros emiten un token JSON, conocido como JWT (JSON Web Token), firmado criptográficamente.

En todo caso, las medidas para conservar de manera segura el token y transmitirlo de manera segura son responsabilidad de la aplicación.

PKCE

En el mecanismo descrito anteriormente existe un riesgo de seguridad, especialmente en dispositivos móviles o clientes públicos: un proceso malicioso podría interceptar el código de autorización y usarlo para conseguir un token de acceso. Con este token podría acceder al recurso protegido.

PKCE, Proof Key for Code Exchange, no es un sistema de autenticación del cliente, sino que es un mecanismo para asegurar que la aplicación que solicita el código de autorización es la misma que la aplicación que usa el código de autorización para conseguir el token de acceso. Es decir, en el diagrama anterior, que la aplicación que inicia el paso 2 es la misma que la que inicia el paso 6.

Para usar PKCE, la aplicación crea una cadena de texto aleatoria, el «code verifier», suficientemente larga para que no pueda ser averiguada. A partir de ella computa un «code challenge» (un *hash*), que envía en el paso 2 junto con el método de cálculo empleado. Después, cuando envía el código de autorización en el paso 6, envía también la cadena inicial (el «code verifier»). El servidor de autorización puede repetir el cálculo y así asegurarse de que la aplicación que solicita el token de acceso es la misma que solicitó el código de autorización.

OpenID Connect

De todo lo anterior es evidente que OAuth 2 proporciona un marco para la gestión de la autorización de las aplicaciones que llaman a APIs, pero no está diseñado para autenticar a los usuarios de las aplicaciones.

El protocolo OpenID Connect (OIDC) proporciona una capa de servicios de identidad por encima de OAuth 2. Esta capa ha sido diseñada para que los servidores de autorización puedan también autenticar a los usuarios de las aplicaciones.

En OIDC, el servidor de autorización pasa a llamarse «OpenID Provider», que es el término que usaremos al referirnos a este protocolo.

Cuando un usuario quiere acceder a una aplicación, desde el navegador se le reenvía al OpenID Provider, que interactúa con el usuario para autenticarlo. Tras la autenticación, se le redirige a la aplicación y se adjunta un token, denominado «ID Token».

Como OIDC es una capa por encima de OAuth 2, las aplicaciones pueden usar el OpenID Provider tanto para la autenticación como para la autorización.

Ejemplo de ID Token en formato JWT:

Encabezado (algoritmo y tipo de token) <pre>{ "alg": "RS256", "typ": "JWT" }</pre>
Carga útil (atributos) <pre>{ "iss": "http://openidprovider.com", "sub": "1234567890", "aud": "2fb3JsPMrOnQkwLEVNMDzUF", "nonce": "47jglwDhmXo2hgDewhg9528H", "exp": 1516239322, "iat": 1516239022, "name": "Federico Chopin", "admin": true, "auth time": 1516239021, "acr": "I", "amr": "pwd" }</pre>
FIRMA

El OpenID Provider firma el token de identidad según la especificación JWS (JSON Web Signature). La aplicación que lo recibe puede validar esta firma siguiendo la misma especificación.

Un token de identidad puede incluir más información que la que se ve en la imagen. Algunos campos estándar que se pueden añadir opcionalmente son: nombre de usuario, nombre, apellido, correo, *locale* (país), y una imagen, entre otra. La especificación de OIDC incluye una lista de campos adicionales que se pueden incluir en el token.

OIDC define 3 flujos diferentes, de los cuales en este tema sólo se detalla uno, el «flujo de autorización» que combina tanto la autenticación como la autorización. Es muy similar al flujo de OAuth 2:

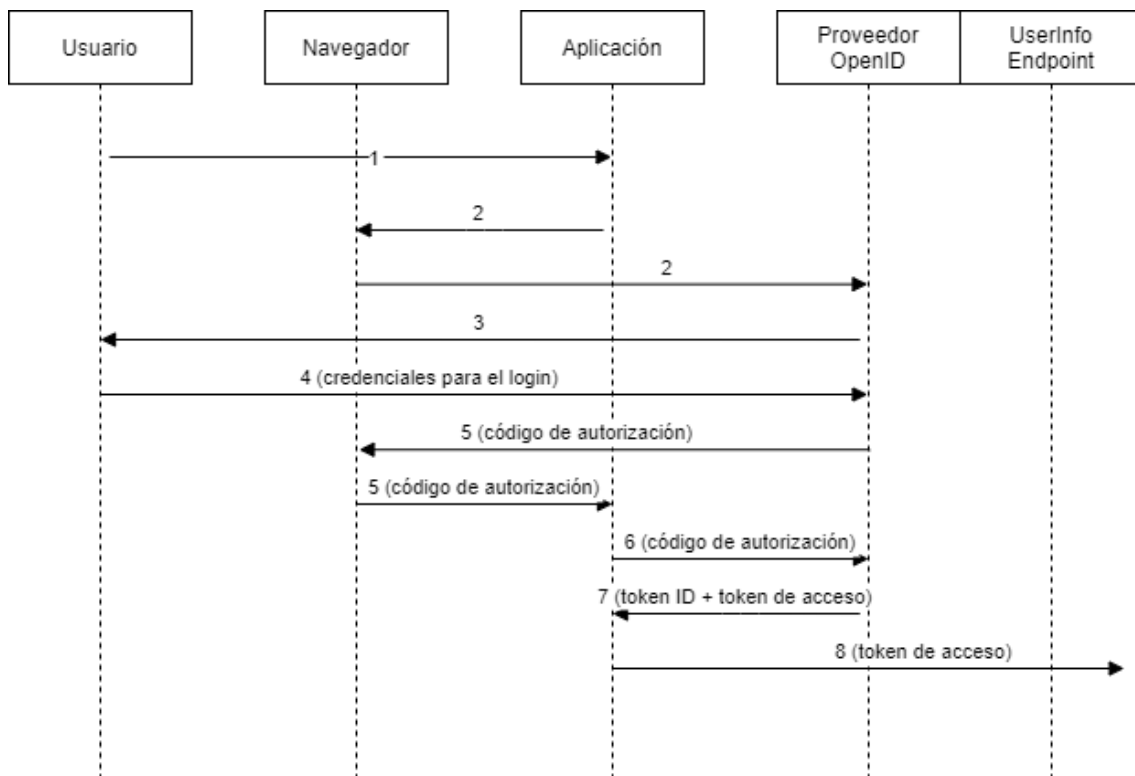


Imagen 8: Diagrama de secuencia de una autenticación usando OpenID.

1. El usuario accede a la aplicación.
2. Desde la pantalla de login de la aplicación, se redirige el navegador del usuario al OpenID Provider con una solicitud de autenticación.
3. El OpenID Provider interactúa con el usuario para la autenticación y para recabar su consentimiento para el acceso solicitado al recurso.
4. El usuario se autentica y proporciona su consentimiento.
5. Se redirige el navegador del usuario de vuelta a la aplicación, con un código de autenticación.
6. La aplicación solicita el token al OpenID Provider, con el código de autorización.
7. El OpenID Provider proporciona un ID Token y un token de acceso.

En resumen, el protocolo OIDC proporciona una capa sobre OAuth 2 que soporta la autenticación de un usuario en una aplicación. Como se construye sobre OAuth 2, también permite gestionar el control de acceso a una API.

En resumen, en los sitios que soporten OpenID, los usuarios no tienen que crearse una nueva cuenta de usuario para obtener acceso. En su lugar, solo necesitan disponer de un identificador creado en un OpenID Provider (por ejemplo, Facebook o Google). El OpenID Provider autentica al usuario, recoge su consentimiento para acceder a la API y emite un token de identidad y otro de autorización de acceso.

OpenID no especifica el mecanismo de autenticación, por lo tanto, la seguridad de una conexión OpenID depende de la confianza que tenga el cliente OpenID en el proveedor de identidad.

A modo de ejemplo concreto, un usuario podría acceder a una página web de publicación de noticias usando su identidad con Google o Facebook. Estas empresas actúan como OpenID Provider. La seguridad de la autenticación (múltiples factores, cookies, etc.) la gestiona el OpenID Provider, no la web de publicación de noticias. Al hacerlo así, la web de publicación de noticias se evita un esfuerzo considerable, que es la implementación de un sistema de gestión de identidades y accesos. Al mismo tiempo, no tiene que almacenar datos cuya custodia supone un riesgo, como son los de la identidad de sus clientes.

Por otra parte, se debe observar que los mecanismos descritos permiten al OpenID Provider proporcionar poca o mucha información sobre el usuario. Se debe valorar en cada caso concreto qué información es relevante, y el usuario debe prestar su consentimiento a la información que el proveedor de identidad va a ceder a otras aplicaciones.

5.5. Soluciones IAM para entornos de nube híbrida y multinube

5.5.1. Microsoft Entra (antes Azure AD)

Es una solución IAM completa, sólo disponible en modalidad SaaS. Es diferente de Active Directory, con el que no se debe confundir.

Se utiliza principalmente para la gestión de la identidad de los trabajadores (y colaboradores) de una organización, pero no se usa con tanta frecuencia para la identidad de los clientes de la organización.

Además de ofrecer un servicio de directorio en la nube, Azure AD permite la autenticación multifactor usando SMS, email o la app móvil Microsoft Authenticator. También proporciona capacidades de acceso adaptativo (ABAC o RadAC, como se han descrito en el apartado 2.3 de este tema).

Proporciona Single Sign-On entre aplicaciones web usando elementos de federación de identidades, como los que se han visto en apartados anteriores: SAML 2, WS-Federation y OpenID Connect. Por supuesto, esto sólo es posible con las aplicaciones que han implementado alguno de estos protocolos.

Dado que en el entorno tradicional (en dominios de seguridad en redes de área local) se usa masivamente Active Directory, un problema habitual en un entorno de nube híbrida es encontrarse con dos proveedores de identidad diferentes. Por ejemplo, una organización podría encontrarse con que dispone de un servidor Active Directory en local (en su CPD) que se utiliza para microinformática, impresoras y acceso a servidores y aplicaciones locales, mientras que se utiliza Azure AD en la nube para el acceso a las aplicaciones web.

Activando y configurando los servicios de federación de Active Directory, AD FS, es posible federar el directorio local con el proveedor de identidad en la nube, de modo que ambos estén sincronizados.

Cuando un usuario inicia sesión en una aplicación, en primer lugar, se le muestra una página de inicio de sesión de Azure AD. Una vez que escribe su UPN (User Principal Name), si está en un dominio federado, se le redirige a la página de inicio de sesión del IdP que sirve a ese dominio¹.

Desde el año 2023, Microsoft ha cambiado el nombre a Azure AD, que ahora se llama Microsoft Entra ID. Entra proporciona funcionalidades adicionales de seguridad y gobierno.

5.5.2. Okta

Okta es otra plataforma de identidad SaaS, es decir, sólo se ofrece como servicio desde la nube. Permite la gestión de identidades, la autenticación multifactor y adaptativa, y el control de accesos.

Dispone de capacidades excelentes para el SSO, utilizando SAML 2, OpenID Connect, RADIUS y soporte para el protocolo LDAP. También dispone de integración con numerosas soluciones heredadas (*legacy*) de SSO, por lo que en muchos casos se puede utilizar para el acceso a la infraestructura local también.

También dispone de muy buenas capacidades en lo que respecta a los flujos de trabajo para la administración de usuarios (altas, bajas, modificación), usando el producto Lifecycle Management, que permite automatizar tareas de creación de usuarios, delegar las tareas, y automatizar las bajas (por ejemplo, cuando no hay actividad desde cierto tiempo).

Okta se posiciona como un proveedor *neutral* y abierto, compatible con una amplia variedad de tecnologías, aunque el coste es elevado.

Las soluciones de Okta se emplean ampliamente para gestionar la identidad de los trabajadores de una organización, pero también las de los clientes y consumidores. En el caso de los consumidores, a menudo se realiza mediante procesos de creación de cuenta por el propio usuario, sin intervención de ningún trabajador de la organización. En el caso de los trabajadores, a menudo se necesita confirmación de algún trabajador dado de alta previamente (por ejemplo, el responsable del nuevo trabajador que se incorpora), para lo cual Okta dispone de flujos de trabajo que permiten automatizar la tarea.

5.5.3. Ping Identity y ForgeRock

Aunque eran dos empresas separadas, ambas en posición de liderazgo en el campo del IAM, Ping Identity ha adquirido ForgeRock en el año 2023. Por eso se presentan en conjunto.

ForgeRock comercializa su solución IAM como servicio en la nube (SaaS) o como solución instalable en infraestructura local. Ofrece buenas capacidades en control de accesos adaptativo y autenticación multifactor.

¹ <https://learn.microsoft.com/es-mx/azure/active-directory/manage-apps/home-realm-discovery-policy>

Igualmente, Ping Identity ofrece sus soluciones como servicio en la nube (SaaS) o como producto instalable en infraestructura local.

5.5.4. Otros proveedores destacados

Otros proveedores de soluciones IAM modernas son:

- **CyberArk**, cuya solución está disponible en modalidad SaaS. CyberArk es una empresa con una amplia cartera de productos en materia de PAM (Privileged Access Management), que son los accesos con privilegios elevados (como los administradores de sistemas, por ejemplo) y que requieren de una mayor seguridad. La oferta de CyberArk combina la solución IAM con soluciones PAM. Muchos clientes de CyberArk empezaron instalando la solución PAM y luego la ampliaron para hacer una gestión de la identidad y los accesos más extensa.
- **IBM** dispone de una solución en modalidad SaaS, IBM Security Verify, y de una solución instalable en infraestructura local, IBM Security Verify Access. Dispone de muy buena integración con otros productos de seguridad de IBM.
- **One Identity (OneLogin)** es el resultado de la adquisición de OneLogin por One Identity. Al igual que CyberArk, One Identity ha llegado a sus soluciones IAM desde soluciones PAM con buena implantación previa.
- **Thales**, que tras la adquisición de OneWelcome (ambas europeas) ha pasado de especializarse en sistemas de alta seguridad mediante tokens y tarjetas físicos a disponer de una solución IAM completa para todo tipo de escenarios, aunque es de prever que necesitará algo de tiempo para la integración.

6. Gestión de identidad en las AAPP

6.1. AAPP en España

Entre las Administraciones Públicas existen numerosos casos de uso en el que se utiliza el SSO y la gestión de identidades para que los empleados públicos puedan acceder a los diferentes recursos dentro de su organización (dominio de seguridad). Dichos casos no difieren de los utilizados en cualquier empresa privada.

Una cuestión muy diferente es lo que ocurre desde el punto de vista del ciudadano, que para la Administración Pública puede ser entendido como «el cliente». Muchas empresas privadas que prestan servicios en la nube o que venden aplicaciones, suscripciones o contenidos, no tienen que preocuparse de la identidad de sus usuarios. Por ejemplo, una revista online, un servicio de correo web o una tienda online no tienen ningún problema si un usuario abre dos cuentas, o si durante un tiempo deja de pagar la suscripción y después se reincorpora desde otra cuenta. Tampoco les preocupa si dos usuarios comparten una misma cuenta (salvo por la pérdida de negocio que les pueda causar). En cambio, **en la Administración Pública es fundamental identificar y autenticar correctamente al ciudadano**. Sería impensable que un ciudadano “abriera dos cuentas» o «compartiera una cuenta» (se deja a la imaginación del lector interpretar qué significaría algo así en el Registro Civil, en los antecedentes penales, en el historial clínico o en el expediente educativo, por poner algunos ejemplos).

Por eso una preocupación esencial de las Administraciones Públicas de todos los países es precisamente la identificación de sus clientes, que por desgracia nunca podrá ser tan sencilla como la de muchos proveedores de servicios web.

En España se ha hecho un gran esfuerzo por implantar la identidad digital, incluyendo tanto la identificación como la autenticación de los ciudadanos. El enfoque que se ha adoptado es el de las infraestructuras de claves públicas (PKI).

En España existen varias autoridades de certificación (AC) que pueden emitir certificados. Existe además una pasarela única para el acceso a las aplicaciones de la Administración Pública, que es Cl@ve. Cl@ve se integra con las diferentes AC para poder validar los certificados de todas ellas, lo que significa que un ciudadano puede acceder a los servicios públicos digitales con un certificado emitido por cualquiera de ellas. Algunas de la AC más conocidas en España son la Dirección General de la Policía, la Fábrica Nacional de Moneda y Timbre, la Generalitat Valenciana (ACCV), la Agència Catalana de Certificació (CATCert), AC Camerfirma, la Autoridad de Certificación de la Abogacía (ACA), etc.

Además de con los certificados emitidos por las AC, Cl@ve se integra con dos proveedores de identidad, la AEAT y la GISS.

Cada uno de estos actores (las diferentes AC, la AEAT y la GISS) es en realidad un proveedor de identidad diferente. Cuando el ciudadano se autentica, lo hace con los medios de autenticación del proveedor correspondiente. Así, la autenticación mediante Cl@ve PIN es un servicio que

presta la AEAT, y la autenticación mediante Clave Permanente es un servicio que presta la GISS. Para el uso de estos servicios se requiere de registro previo.

El servicio Cl@ve también actúa como nodo eIDAS español.

Círculos de Confianza

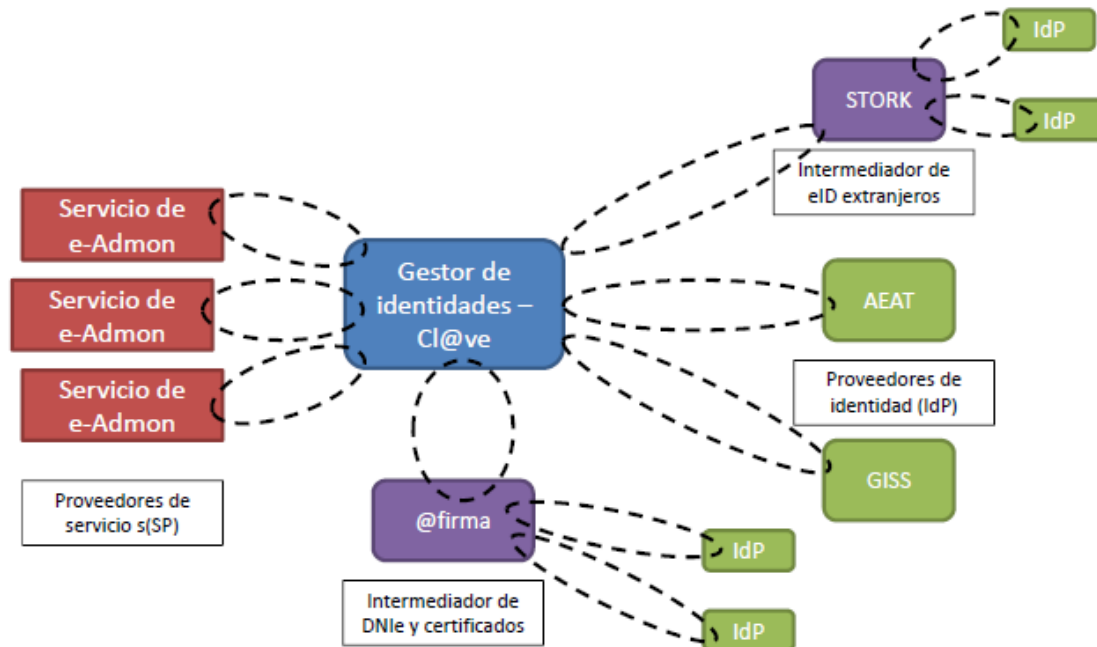


Imagen 9: Círculos de confianza de Cl@ve.

Fuente: PAE, <https://administracionelectronica.gob.es/ctt/resources/Soluciones/766/Descargas/Cl-ve%20Identificacion.pdf?idIniciativa=766&idElemento=12264> página 8.

Cl@ve permite la federación de identidades utilizando el protocolo SAML.

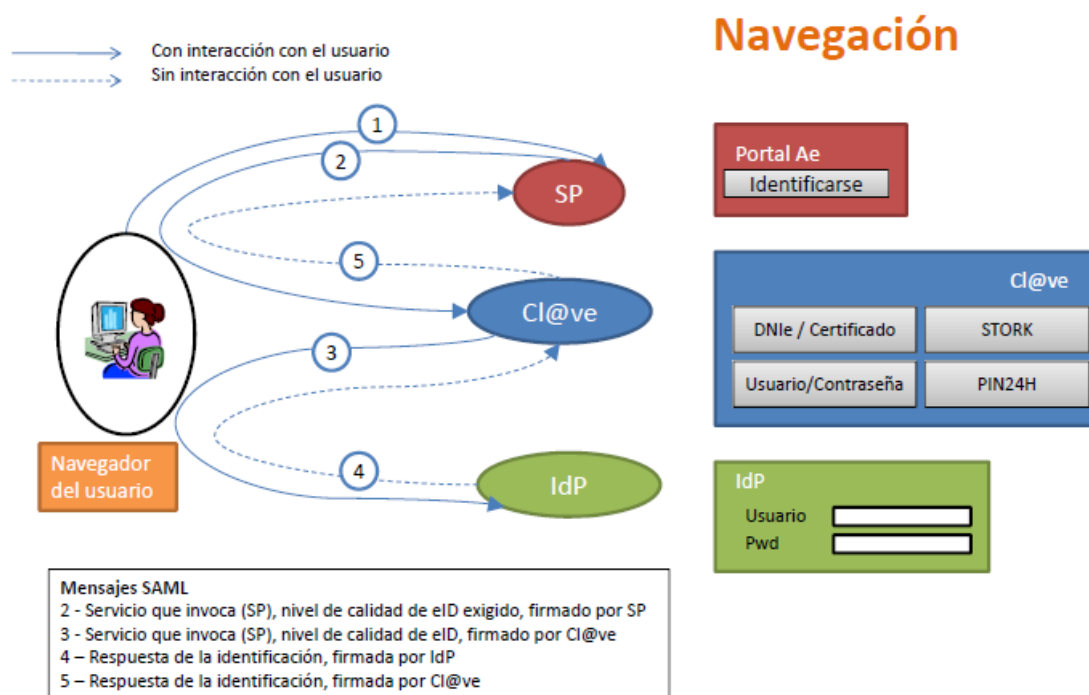


Imagen 10: Secuencia de una autenticación usando Cl@ve.
Fuente: PAE, <https://administracionelectronica.gob.es/ctt/resources/Soluciones/766/Descargas/Cl-ve%20Identificacion.pdf?idIniciativa=766&idElemento=12264> página 15.

6.2. Unión Europea

La capacidad de poder realizar trámites transfronterizos por Internet entre los diferentes países de la UE, utilizando la identidad digital europea, es una necesidad clara para avanzar en el Mercado Único y la integración entre los países europeos.

El Reglamento (UE) 910/2014 relativo a la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior busca conseguir un clima de confianza para las transacciones electrónicas en el mercado interior. Este Reglamento establece el marco normativo para la identidad digital europea. Es objeto del Tema 80, por lo que no se desarrolla en el presente tema.

En los últimos años la Comisión Europea ha continuado los esfuerzos que empezaron en el año 2008 con el proyecto Stork y que dieron lugar al Reglamento eIDAS. En septiembre del año 2020 la Comisión Von der Leyen lanzó el proyecto de una identidad electrónica europea segura. El objetivo es que el ciudadano pueda controlar qué datos se utilizan y cuáles no, almacenándolos en un «wallet» o cartera digital y facilitando para cada transacción sólo aquellos que sean necesarios. Para que resulte útil, tiene que poder utilizarse ampliamente como medio de identificación o para confirmar determinada información al acceder a servicios digitales tanto públicos como privados.

En el año 2021, la Comisión Europea propuso al Parlamento un Reglamento que modifique el Reglamento 910/2014 para poder desarrollar esta identidad digital. A fecha actual no ha sido aprobado².

En el año 2023 se ha publicado una arquitectura de referencia³.

² https://commission.europa.eu/strategy-and-policy/priorities-2019-2024/europe-fit-digital-age/european-digital-identity_es#documentos

³ <https://digital-strategy.ec.europa.eu/en/library/european-digital-identity-wallet-architecture-and-reference-framework>

7. Teletrabajo y trabajo en movilidad

El trabajo a distancia o teletrabajo es una estrategia que permite a las organizaciones posibilitar la continuidad del trabajo a los empleados que, por determinadas circunstancias, no pueden acudir a su centro de trabajo habitual.

Con la llegada de la pandemia COVID-19, el teletrabajo experimentó un auge forzoso.

7.1. Teletrabajo y Administración Pública: Marco Normativo

Los antecedentes de la incorporación del teletrabajo en la Administración Pública española deben buscarse en la preocupación de las organizaciones por la conciliación de la vida profesional y personal de los trabajadores. El Consejo de Ministros, en 2005, aprobó el Plan Concilia que recoge una serie de medidas para hacer posible la conciliación en el ámbito público.

Con el advenimiento de la pandemia de covid en el año 2020, durante el confinamiento se generalizó una situación de trabajo a distancia que no había podido ser planificado. En opinión personal del autor de este tema, no se trató tanto de teletrabajo, como de una solución para la continuidad del negocio».

Con la mayoría de la población vacunada y los efectos del covid en receso, se modificó el Estatuto Básico del Empleado Público en el **Real Decreto Legislativo 5/2015**, añadiendo el **artículo 74.bis** sobre teletrabajo. Se considera que tendrá carácter «voluntario y reversible», y habrá de ser «expresamente autorizado». Se pone especial énfasis en la «identificación de objetivos y la evaluación de su cumplimiento», piedra angular de un verdadero modelo de teletrabajo.

La Administración debe proveer los medios tecnológicos necesarios para la actividad del trabajador, aunque otros medios (silla, mesa, luz, etc.) correrán por cuenta del trabajador.

Fuera del ámbito administrativo, en el sector privado, que supone el grueso de la economía española, es el artículo 13 del Real Decreto Legislativo 2/2015, por el que se aprueba el texto refundido de la Ley del Estatuto de los Trabajadores, el que remite a la Ley 10/2021 de trabajo a distancia.

La Ley 10/2021 distingue entre el «trabajo a distancia», desde el domicilio de la persona trabajadora y con carácter regular, y el «teletrabajo», que es el trabajo a distancia realizado mediante el uso prevalente de sistemas informáticos.

Establece el principio de igualdad de trato, de oportunidades y de no discriminación entre las personas que desarrollan trabajo a distancia y las que prestan servicios en el centro de trabajo de la empresa.

El trabajo a distancia es voluntario para ambas partes y requiere la firma de un «acuerdo de trabajo a distancia». Este acuerdo deberá ponerse por escrito e incorporarse al contrato y reflejará cuestiones como el inventario de medios, gastos que le supone a la persona trabajadora, horario, lugar de trabajo a distancia elegido por la persona trabajadora, etc. (ver artículo 7 Ley 10/2021).

7.2. Trabajo en movilidad o itinerancia

El *trabajo en movilidad*, o *trabajo en itinerancia*, es ligeramente diferente del teletrabajo, aunque se superpone en algunos aspectos. Se denomina trabajo en movilidad al trabajo que realiza un empleado de la organización que, por razón de su puesto, tiene que desplazarse y conectarse desde ubicaciones que no son la oficina. Algunos ejemplos serían las Fuerzas y Cuerpos de Seguridad del Estado, que normalmente tienen que trabajar fuera de su «puesto de trabajo» en una oficina; pero también un empleado de la oficina de prensa de un Ministerio, que tiene que acompañar al personal directivo a reuniones, eventos y entrevistas y trabajar desde esos entornos; o una Ministra que tiene que conectarse desde ubicaciones cambiantes porque su puesto le exige una alta movilidad, a veces incluso desde otras ciudades españolas o europeas; o una funcionaria de una unidad TIC que trabaja en el Área de Explotación y tiene que atender las incidencias cuando está de guardia, desde su domicilio o incluso desea conectarse cuando está de vacaciones en la playa.

Todas estas situaciones, y muchas más, serían ejemplos de trabajo en movilidad. Es posible que algunos de los ejemplos anteriores no sean casos de teletrabajo, y sin embargo comparten la necesidad de conectarse y poder realizar todas o algunas de sus tareas en itinerancia.

7.3. Tecnologías que permiten el acceso remoto a los sistemas corporativos

Se presentan a continuación diferentes opciones para solucionar el acceso remoto a los sistemas corporativos.

7.3.1.a. Escritorio remoto (*Remote Desktop*)

El escritorio remoto es el nombre que se da a la posibilidad de conectarse en remoto al escritorio del ordenador de sobremesa (o portátil) desde otro ordenador.

El acceso remoto permite a los usuarios conectarse a su propio escritorio mientras están físicamente lejos de su ordenador. En el escenario típico, el ordenador del trabajador está físicamente ubicado en su centro de trabajo, es decir, en la oficina. Este ordenador tiene que estar encendido. Con el ordenador encendido, y si las conexiones de red están abiertas, el trabajador puede conectarse desde otro ordenador *fuera del centro de trabajo* (por ejemplo, en su casa) al ordenador en su centro de trabajo.

Los sistemas que soportan el **X Window System**, típicamente los basados en Unix, tienen esta capacidad incorporada. Las versiones de Windows cuentan con una solución incorporada para el acceso remoto bajo la forma de **Remote Desktop Protocol**.

Cuando un usuario se conecta a su ordenador de la oficina desde otro, por ejemplo, desde su ordenador doméstico en casa, tiene que iniciar sesión. Un ordenador Unix o Linux permite cualquier número de sesiones remotas simultáneas; en cambio, un ordenador Windows sólo permite 2 sesiones remotas simultáneas.

El ordenador doméstico desde el que se conecta el usuario en su casa se denomina a veces «cliente», y el ordenador de la oficina se denomina «ordenador remoto».

El usuario, al conectarse con el cliente al ordenador remoto, accede en primer lugar a la pantalla de login del ordenador remoto. Debe identificarse (nombre de usuario) y autenticarse (contraseña), y al hacerlo abre una sesión de usuario en el ordenador remoto. De esta manera, verá en su pantalla en casa la misma pantalla que vería si estuviera en la oficina. No sólo eso, sino que tendrá acceso a las aplicaciones que estén instaladas en el ordenador remoto, y a todos los archivos que tenga almacenados en local. También tendrá acceso a las aplicaciones corporativas internas y a las unidades de red a las que le han concedido permisos.

Además de las anteriores opciones nativas, existen innumerables programas que permiten compartir el escritorio con un tercero, como Team Viewer o Anydesk, por ejemplo, aunque hay que estudiar con mucho cuidado si permiten iniciar sesión en remoto. Normalmente no debe asumirse que estas herramientas puedan usarse como escritorios remotos, pero algunas pueden habilitar esta función.

Condiciones de uso

Para poder usar los escritorios remotos como medio para el teletrabajo, se debe tener en cuenta, al menos, lo siguiente:

- El ordenador remoto (en la oficina) debe estar constantemente encendido. Por un lado, supone un despilfarro energético. Por otro lado, esto genera numerosos problemas: saltan los fusibles por problemas en el suministro eléctrico y de repente numerosos empleados no pueden conectarse; el usuario «apaga» el ordenador por error al terminar su sesión (en vez de simplemente cerrar sesión al terminar); etc. Si no hay compañeros cerca a los que llamar para que lo vuelvan a encender, puede suponer un verdadero contratiempo. Por esta razón y otras relacionadas con la gestión, muchos ordenadores corporativos disponen ahora de una opción denominada «Wake on LAN», que permite encenderlos remotamente desde el CAU u otro centro de gestión.
- El ordenador remoto (en la oficina) debe estar expuesto a Internet. Esto no es trivial: normalmente los equipos en las redes de usuario no salen a Internet salvo por unos pocos puertos muy concretos. En general, no es posible desde Internet *llamar* a un ordenador en una red de usuario. El firewall y otros sistemas defensivos lo impiden. Sin embargo, para que funcione RDP o X Window se requiere abrir un puerto determinado en el firewall (3.389 para RDP, aunque se puede cambiar por otro que determine la organización) y permitir llamadas entrantes desde Internet. Esto es extremadamente peligroso, puesto que, si un atacante malicioso consiguiese explotar alguna vulnerabilidad del protocolo o del sistema de control de accesos, podría tomar el control de esa máquina. Se conocen numerosos ejemplos de ataques, a menudo de tipo *man-in-the-middle* o explotando vulnerabilidades del protocolo RDP.
- Para mejorar la seguridad, a menudo se securiza mediante una VPN y un sistema de autenticación multifactor (por ejemplo, usando RADIUS). Esto hace que el usuario se conecte primero al terminador de túnel de la VPN y desde allí, a su ordenador remoto. Sin embargo, es necesario instalar y configurar el cliente de VPN en el ordenador cliente,

lo cual puede resultar complejo si el ordenador cliente es el ordenador doméstico del usuario o es un ordenador desconocido (cibercafé, etc.).

- El ordenador cliente no necesita una gran capacidad. Lo único que va a hacer es conectarse y visualizar el escritorio remoto. A menudo puede ser algo tan sencillo como un *thin client* o un Chromebook. Esto reduce el coste potencial de esta opción.
- Es difícil conectarse y trabajar en itinerancia, por ejemplo, desde una tableta o un teléfono móvil, puesto que lo vemos es el escritorio del ordenador de sobremesa con la resolución que tenga y con una versión de Windows que no está adaptada a dispositivos móviles.

Ventajas, inconvenientes y escenarios de uso

De todo lo anterior, es evidente que el sistema de escritorios remotos es *muy barato*, pues no hay que comprar equipos ni licencias nuevas, sino que está disponible como parte de Windows y de Linux. Además, es muy cómodo para el usuario, que accede a sus archivos y aplicaciones igual que en la oficina. Sin embargo, tiene problemas de seguridad (aunque puede securizarse, como se ha visto) y no se adapta al trabajo en itinerancia.

El CCN los considera un sistema que permite el acceso a sistemas y archivos *de categoría Media*, si está adecuadamente configurado y securizado⁴.

Los escritorios remotos se usaron ampliamente en el año 2020, al estallar la pandemia que forzó al confinamiento de toda la población durante 2 meses. Muchos organismos y unidades de la AGE no disponían de suficientes medios para implantar otras soluciones, pues era necesario la compra de licencias y/o de equipos, como se verá a continuación, y recurrieron a los escritorios remotos (en general, securizados con VPN), a los que se conectaban los empleados desde sus ordenadores domésticos.

En este escenario, más propio de un escenario de «continuidad de negocio» ante un desastre que de teletrabajo propiamente dicho, los escritorios remotos están siempre disponibles, pues son un componente más de Windows y de Linux y no se requiere ninguna inversión adicional. Esto permitió dar respuesta rápidamente a unos acontecimientos absolutamente imprevisibles.

Sin embargo, el modelo también demostró numerosos problemas: era necesario instalar clientes VPN en los ordenadores domésticos de los trabajadores, abrir puertos y exponer los ordenadores en la organización a posibles atacantes maliciosos, muchos empleados públicos manifestaron su desacuerdo con tener que utilizar sus medios personales para el trabajo, etc.

7.3.2. Portátil y VPN

Una alternativa evidente a lo anterior es sustituir los ordenadores de sobremesa de los trabajadores por ordenadores portátiles. Esta opción es más cara, pues en general los ordenadores portátiles son más caros que los ordenadores de sobremesa (es decir, para las

⁴ <https://www.ccn.cni.es/index.php/es/docman/documentos-publicos/abstract/191-abstract-politica-de-acceso-remoto-seguro/file>, página 6, 3.2.3 b).

mismas prestaciones, suele ser más caro un portátil que un sobremesa). El coste se multiplica por el número de ordenadores a adquirir.

Condiciones de uso

Para poder usar los escritorios remotos como medio para el teletrabajo, se debe tener en cuenta, al menos, lo siguiente:

- En general se trata de una conexión VPN multipunto a un único punto, con los trabajadores remotos conectándose todos a un equipo que actúe como terminador de túnel en la red de la organización.
- Existen múltiples tecnologías posibles. Las más habituales son:
 - Transport Layer Security, TLS: es el protocolo más habitual en los terminadores modernos. Tiene la ventaja de funcionar en casi todas las redes y ser tráfico permitido en casi todos los firewalls.
 - Point-to-Point Tunneling Protocol (PPTP): definido por un grupo de empresas y estandarizado en 1999 en la RFC 2637. Encapsula paquetes PPP y crea un túnel sobre redes IP. No modifica PPP, simplemente define una forma de transportarlo en redes IP.
 - Layer 2 Tunneling Protocol (L2TP): misma funcionalidad que PPTP, pero sobre redes que no son IP. Puede combinarse con IPSec, en cuyo caso L2TP proporciona sólo las funcionalidades de autenticación y cifrado.
 - Internet Protocol Security (IPSec): autentica y cifra cada paquete IP. Proporciona autenticación y cifrado usando dos protocolos de seguridad, Authentication Header (AH) y Encapsulating Security Payload (ESP). Puede usarse en modo de transporte o en modo túnel.
- Con cualquiera de estos protocolos, cuando se conecta a través de la VPN el equipo del usuario recibe una dirección IP en la red de área local de la organización. De esta manera dispone de acceso a las mismas aplicaciones y unidades de red que cuando está en la oficina.
- En este escenario, lo más habitual es implantar una política de «equipo único». El usuario sólo dispone del portátil, que debe usar tanto en la oficina como en su domicilio. Esto significa que el usuario debe transportar el portátil de su casa a la oficina y viceversa.
- El usuario siempre dispone en su equipo de trabajo de los archivos que se ha descargado a local, tanto cuando está en su casa como en la oficina. En este sentido, es la solución más sencilla.
- Existen numerosas soluciones hardware y software que pueden actuar como terminador de túnel VPN. En el mercado se pueden encontrar productos dedicados, que funcionan únicamente como terminadores de túnel, pero también la mayoría de firewalls modernos pueden realizar esta función. La elección entre un terminador dedicado o utilizar el firewall dependerá en gran parte del dimensionamiento. Para unos pocos usuarios es posible utilizar el firewall, pero si se prevé que se implante una política de teletrabajo duradera, es mejor dotarse de un terminador de túnel dedicado, independiente del firewall. El cifrado con cualquiera de los protocolos indicados es una labor intensiva en cómputo, y podría saturar el firewall cuando el número de usuarios crece.

- Aunque existen numerosísimos productos que se pueden usar como terminadores de túneles, algunos de los más habituales en la AGE o más conocidos son Pulse Secure, Ivanti Connect Secure, Citrix Gateway (antiguo NetScaler VPN), Cisco AnyConnect, Zscaler Private Access (ZPA), etc... Igualmente, la mayoría de firewalls modernos también poseen esta capacidad, tales como Checkpoint, Forcepoint, SonicWall, etc.

Ventajas, inconvenientes y escenarios de uso

La opción de equipar con un portátil a todos los empleados (por lo menos a aquellos que tienen la opción de teletrabajar) supone un aumento de los costes en hardware microinformático, comparado con la compra de ordenadores de sobremesa. Además, es necesario instalar y operar un terminador de túnel. Por lo tanto, esta solución es más cara que la anterior.

No obstante, a pesar del aumento de costes esta opción es la más popular en la actualidad. Numerosas organizaciones han optado por esta vía, y es la solución más habitual en la AGE.

Si la VPN se configura siguiendo las instrucciones del fabricante, se revisan las guías CCN STIC apropiadas, y se mantiene el software actualizado en el cliente y el terminador, es una solución muy segura. El CCN considera que es una solución válida para el acceso a sistemas categorizados con nivel Alto.

No obstante, asociado al uso masivo de los portátiles en la organización se debe tener en cuenta la aparición de un riesgo importante, que con los ordenadores de sobremesa no existía. Normalmente los portátiles son dispositivos gestionados por la organización (es decir, están enrolados en el UEM de la organización, controlados en remoto por ésta, disponen de antivirus y otros programas de seguridad instalados y están sujetos a las políticas de seguridad definidas). A pesar de todo ello, siguen siendo portátiles que van a utilizarse en el exterior de la organización y que pueden conectarse a redes WiFi, a veces inseguras. No es posible evitar que ocasionalmente el trabajador, fuera de su horario laborable, los utilice para fines personales. En ese momento el ordenador se conecta a Internet sin activar la VPN, por ejemplo, a través de la red WiFi familiar. Eso significa que no está sujeto a toda la seguridad implantada en la red de área local corporativa: firewall, proxies, IDS/IPS, DLP, XDR, etc. En esos momentos, el equipo resulta especialmente vulnerable. Si un atacante toma el control del equipo en ese momento, cuando el portátil vuelva a conectarse a la red corporativa, ya sea a través de la VPN o porque el trabajador se conecta desde la propia oficina al día siguiente, el atacante se encontrará dentro de la red corporativa.

Como contramedidas, dentro de la red corporativa es necesario limitar al máximo los accesos permitidos desde las redes de usuario, tanto las correspondientes a equipos conectados por VPN como las de equipos presenciales, pues todos resultan igual de peligrosos. También es recomendable monitorizar cuidadosamente estas redes.

La conexión mediante VPN es una solución mediocre para el trabajo en movilidad o en itinerancia. En general es posible conectar un teléfono o una tablet a través de una VPN, pero suele presentar problemas de ergonomía, de disponibilidad de clientes, etc.

7.3.3. Escritorio virtual y escritorio como servicio (DaaS)

/!! Aunque se describe en este tema desde la perspectiva del teletrabajo, los escritorios virtuales son una tecnología con múltiples aplicaciones. Se puede encontrar más información al respecto en el tema 132, virtualización del puesto de trabajo.

Esta es la opción más cara y compleja, pero posiblemente también la más segura.

Un escritorio virtual es un ordenador virtual en un servidor dentro de la organización. Es decir, se dispone de un servidor en el que se levantan máquinas virtuales con las características de un ordenador personal y con licencia de Windows o de Linux. La organización es responsable de toda la pila tecnológica, desde el hardware en el CPD hasta las licencias de virtualización y las de sistemas operativos.

El usuario accede desde su navegador o desde un cliente pesado a este ordenador virtual remoto.

Es la opción más segura, puesto que el ordenador remoto nunca sale de la organización, sin los inconvenientes de RDP y de tener numerosos ordenadores de sobremesa encendidos a la vez.

Sin embargo, también es la solución más cara, pues la memoria RAM y el disco en servidor siempre son más caros que en un portátil o un ordenador de sobremesa. Es decir, 16GB de RAM de servidor son mucho más caros que los mismos 16GB de RAM en un portátil.

No sólo eso, sino que es necesario adquirir licencias de virtualización y de gestión de los escritorios remotos. Existen varios productos en el mercado. Los más conocidos son Citrix Virtual Apps and Desktops y VMware Horizon, aunque en los últimos años han aparecido opciones de menor coste como la empresa española Virtual Cable con su producto UDS Enterprise.

En los últimos años, los grandes proveedores de infraestructura en la nube (IaaS) también han empezado a ofrecer escritorios virtuales en la nube. A veces esto se denomina DaaS (Desktop as a Service). Simplifica mucho el despliegue, puesto que en pocos minutos se puede disponer de todos los escritorios que se desee (aunque se debe valorar el coste, por supuesto). Los dos más conocidos son Azure Virtual Desktop y Amazon Workspaces. Y junto a los grandes proveedores hiperescalares de infraestructura, existen proveedores especializados en DaaS, como son Workspot e Itopia, entre otros.

Por último, también debe tenerse en cuenta el coste en licencias del sistema operativo en el escritorio virtual, así como de otras licencias que puedan ser necesarias (ofimática, por ejemplo). Este coste a veces se ignora al contabilizar el coste total de la solución, pero puede ser una partida significativa del mismo. Efectivamente, cada escritorio virtual que se levanta debe tener una licencia de Windows o Linux, así como las licencias de otros programas que utilice: programas de ofimática, edición de documentos, edición multimedia, etc.

Normalmente la organización dispone de plantillas de máquinas virtuales, que asigna a los trabajadores. Por ejemplo, una plantilla podría servir para levantar ordenadores con Windows 10, 8GB de RAM y 256GB de disco duro; mientras que otra plantilla podría servir para levantar ordenadores con Windows 11, Office 365 y Adobe Acrobat, 16GB de RAM y 512GB de disco duro. Se deberá determinar cuántas plantillas son necesarias para la organización, de modo que a cada perfil se le pueda asignar alguna plantilla.

Al preparar las plantillas es importante asegurarse de automatizar los procesos de generación del escritorio virtual, de forma que todos los escritorios virtuales tengan correctamente configurada la red, el acceso a unidades de red, el antivirus, las políticas de seguridad, la integración con el UEM, etc.

Ventajas, inconvenientes y escenarios de uso

El inconveniente más obvio es el elevado coste de este tipo de soluciones. A cambio, son las soluciones más seguras.

El trabajador puede conectarse desde su ordenador doméstico o desde cualquier otro ordenador. Una dificultad que genera el escritorio virtual es que a menudo el trabajador no dispone de los mismos archivos en el ordenador virtual que en su ordenador habitual de trabajo o en el cliente desde el que se conecta en un momento dado.

Para elegir entre una opción DaaS y una opción VDI, se debe tener en cuenta la ubicación de la infraestructura de la organización. Si la organización tiene la mayoría de sus aplicaciones en el CPD, la opción de DaaS puede añadir latencias importantes, pues el usuario se conecta a la nube, pero desde allí tiene que navegar al CPD continuamente. Si en cambio la organización utiliza muchas aplicaciones SaaS, entonces no habrá diferencias de latencia entre un VDI y DaaS. Por último, si las aplicaciones de la organización están en la nube, en IaaS, entonces la opción DaaS del mismo proveedor será la que menos latencia sufra y la solución VDI será la más lenta.

Para elegir entre DaaS y VDI también es necesario considerar los costes. Si los escritorios van a estar encendidos y funcionando la mayor parte del día, durante varios años, sin duda la opción de VDI es mucho más barata. Sin embargo, en muchas organizaciones esto no es así. Si lo que se prevé es un uso puntual (por ejemplo, para una campaña que sólo dura un mes al año), la opción de contratar DaaS y evitar adquirir las licencias e infraestructura que luego no se van a poder aprovechar será la opción económicamente más viable.

En cuanto a la flexibilidad, los proveedores de DaaS definen cierto número de modelos de ordenador disponibles, y sólo se pueden contratar esos modelos. En cambio, VDI ofrece flexibilidad absoluta para dar más potencia a una máquina en particular, o a un tipo de máquina. Con VDI se pueden crear tantos tipos de máquinas diferentes como se necesiten, por lo que bajo esta perspectiva es más flexible que DaaS. Sin embargo, con DaaS es posible aprovisionar escritorios virtuales en pocos minutos, en tanta cantidad como se necesite, y desaproveccionarlos en cuanto dejan de ser necesarios, por lo que bajo la perspectiva de un uso ocasional o esporádico es mucho más flexible que VDI.

Si los escritorios se necesitan con urgencia, por ejemplo, como parte de un plan de continuidad del negocio para continuar la actividad ante un evento catastrófico imprevisible, como el estallido de una pandemia o la ocurrencia de un terremoto, la opción de DaaS es claramente la que mejor permite proporcionar este servicio en un plazo de tiempo absolutamente reducido.

7.3.4. Herramientas de colaboración y publicación de aplicaciones en Internet

Esta opción consiste en publicar las diferentes aplicaciones necesarias para el trabajo en Internet, de modo que no haga falta ningún ordenador en particular para acceder.

Para comprender esta modalidad de trabajo, se puede pensar en varios ejemplos conocidos: el webmail permite consultar el correo electrónico corporativo desde una página web, sin necesidad de instalar un cliente de correo; con Office 365 y otras aplicaciones similares (Dropbox, Nextcloud, Owncloud...) es posible sincronizar archivos y comunicar por chat y videollamada con los compañeros de trabajo, desde dispositivos que no están en la red de área local del organismo.

Eventualmente, si todas las aplicaciones que usa el trabajador están accesibles desde Internet, el trabajador puede conectarse desde múltiples equipos diferentes, incluso su móvil o una tablet, para realizar su trabajo desde cualquier ubicación.

Aunque parece un planteamiento sencillo, publicar una aplicación en Internet es muy arriesgado desde el punto de vista de la seguridad. Existen buenas razones por las que el modelo tradicional de seguridad se basa en desplegar las aplicaciones de uso interno únicamente en la parte interna de la red del organismo, separadas de Internet por una DMZ y dos niveles de cortafuegos de distinto fabricante. Es necesario garantizar la seguridad de cada aplicación que se despliegue en Internet, y esto no es un trabajo trivial.

La tendencia actual hacia las aplicaciones y redes basadas en el principio de «confianza cero» (zero trust) está muy relacionada con este concepto. Bajo un enfoque de zero trust se intenta garantizar la seguridad de la aplicación incluso cuando está publicada en Internet. No es el objetivo de este tema abordar las redes y aplicaciones basadas en el paradigma de confianza cero, que busca superar el modelo tradicional de red organizada en capas de seguridad mediante el uso de firewalls, por lo que simplemente se apunta la relación entre ambos conceptos.

Bajo un modelo de publicación de aplicaciones en Internet, la centralización y la seguridad de la identificación, autenticación y control de accesos son absolutamente críticos. Es muy recomendable implantar la autenticación multifactor y el control de accesos adaptativo (basado en el riesgo).

A medida que las organizaciones van sustituyendo las aplicaciones en infraestructura local por aplicaciones en la nube (SaaS), se va avanzando de manera natural hacia este modelo. Por ejemplo, si una organización sustituye su herramienta ITSM tradicional, en infraestructura local, por otra en la nube, esta herramienta deja de estar disponible únicamente dentro de la red interna de la organización y pasa en cambio a estar disponible desde Internet. Si luego sustituye el gestor documental por otro en la nube, de nuevo esta funcionalidad pasa a estar disponible en la nube. Será fundamental, no obstante, adoptar una solución de gestión de identidades y accesos moderna, como Okta o Ping Identity, como se ha visto en el capítulo anterior.

Es difícil comparar el coste de esta forma de trabajo con las anteriores, puesto que en realidad no hay costes directamente imputables al teletrabajo. A medida que una organización avanza en su camino de adopción de la nube, irá sustituyendo unas herramientas por otras. Pero lógicamente, el coste de la nueva herramienta en la nube no es imputable al concepto de teletrabajo.

De hecho, si una organización necesita implantar una política de teletrabajo en un plazo determinado (unos meses, un año...), no es posible hacerlo por esta vía. Significaría migrar un número de aplicaciones que ya están en uso a otras en la nube, y además publicar aplicaciones en Internet (lo cual no es trivial, en términos de seguridad y riesgos). Si sólo existiera esta opción, se tardaría años en implantar el teletrabajo.

Sin embargo, de forma más o menos parcial muchas organizaciones ya han avanzado algunos pasos en esta dirección. Esto se debe a que la adopción de herramientas de colaboración, de aplicaciones en la nube y la publicación de aplicaciones en Internet facilitan considerablemente el trabajo en movilidad. Este tipo de trabajo no se ve muy beneficiado por ninguno de los planteamientos anteriores (RDP, VPN, VDI, DaaS), pero sí por la implantación de herramientas de colaboración como Office 365, correo web, aplicaciones en la nube o la publicación de aplicaciones en Internet. Todo ello permite a un trabajador conectarse de forma ocasional, incluso en un aeropuerto, en el transporte público o en una reunión presencial fuera de su oficina, y desde cualquier dispositivo, para responder correos, hacer una presentación, revisar y hacer comentarios a un documento, realizar una firma o notificar una incidencia.

8. Conclusiones

En el presente tema se han intentado abordar las posibles soluciones, tecnologías y ámbito normativo que rodean a la gestión de identidades, federación de identidades y acceso remoto. Se espera que este campo continúe en evolución para ofrecer servicios al usuario cada vez más personalizados y conectados.

En cuanto a Internet, a medida que las tecnologías de Autenticación SSO y de Federación de Identidades se sigan extendiendo en la red y ganen popularidad y apoyo, la web parecerá más un sistema operativo donde el usuario accede una vez, y se personaliza en el acto según sus credenciales. Estas tecnologías emergen rápidamente para proporcionar herramientas, cada vez más potentes, con el fin de aumentar la fidelidad del visitante, involucrarlo en la web y potenciar arquitecturas de despliegue de productos elegantes y eficientes con autenticación SSO.

Las Administraciones Públicas y la Unión Europea no son ajenas a lo que ocurre en Internet y, progresivamente, se han ido adaptando a esta nueva forma de personalizar los servicios. Ya se ha avanzado mucho en este aspecto gracias a la identificación y firma a través del DNIe pero este proceso, lejos de pararse, continuará evolucionando para ofrecer, en el marco de la legalidad, los mejores servicios al ciudadano.

9. Preguntas de test

1. ¿Cuál de las siguientes opciones es indispensable para el funcionamiento adecuado de un sistema de gestión de identidades y accesos en una organización grande?

A) La capacidad de autenticación multifactor, porque en la actualidad es demasiado arriesgado utilizar únicamente contraseñas.

B) La capacidad de realizar SSO web, porque en la actualidad todas las organizaciones grandes utilizan un modelo de nube híbrida con numerosas aplicaciones SaaS.

C) Procedimientos para la gestión del ciclo de vida de las identidades y mecanismos de autenticación, que serán implementados por los equipos humanos.

D) Procedimientos para la gestión del ciclo de vida de las identidades y mecanismos de autenticación, que serán automáticos para evitar incidencias debido a la intervención humana.

2. La organización para la que usted trabaja está preparando una campaña comercial de Navidad para la cual se va a contratar a 250 trabajadores durante 5 semanas. Este personal deberá realizar sus funciones desde su domicilio, pues la organización no es muy grande y no dispone de espacio suficiente para alojarlos en su sede. Se espera que se incorporen en 3 semanas. Para desempeñar sus tareas necesitarán acceso a varias aplicaciones que sólo están disponibles desde la red interna de la organización. ¿Cuál de las soluciones siguientes permite realizar la campaña al menor coste y en el plazo indicado?

A) Adquirir 250 ordenadores portátiles con sus correspondientes licencias de ofimática, y enrolarlos en los sistemas internos. Cada trabajador se llevará el portátil a su domicilio y lo usará para conectarse a las aplicaciones internas.

B) Adquirir 250 ordenadores de sobremesa con sus correspondientes licencias de ofimática, ponerlos en marcha en la red interna de la empresa (se ha identificado una sala sin usar donde cabrían los 250 en estanterías), enrolarlos en los sistemas internos y permitir el acceso remoto mediante RDP. Cada trabajador temporal deberá disponer de los medios en su domicilio para poder conectarse al ordenador en la organización.

C) Adquirir la infraestructura necesaria de servidores y almacenamiento, con las licencias de virtualización necesarias para poder hacer funcionar 250 ordenadores virtuales y las licencias de ofimática de cada ordenador, enrolarlos en los sistemas internos y permitir el acceso a estos ordenadores desde el exterior. Cada trabajador temporal deberá disponer de los medios en su domicilio para poder conectarse al ordenador virtual.

D) Contratar 250 escritorios virtuales en la nube (DaaS) con un proveedor de nube que garantice poder desplegar una VPN site-to-site IPSec entre su CPD y el de la organización y contratar las licencias de ofimática. Cada trabajador temporal deberá disponer de los medios en su domicilio para poder conectarse al ordenador virtual.

3. ¿Cuál de los siguientes no es un protocolo para crear una conexión segura entre dos puntos?

- A) L2TP
- B) IPSec
- C) RADIUS
- D) TLS

4. ¿Cuál de los siguientes protocolos puede usarse para la federación de identidades en entornos de servicios en nube multidominio?

- A) CHAP
- B) Oauth 2
- C) OpenID Connect
- D) Todos los anteriores permiten la federación de identidades en entornos web.

5. Un Ministerio acaba de aprobar su política de teletrabajo, que supone que casi todos los empleados podrán teletrabajar pero deberán organizarse de tal manera que ningún día haya más del 20% de los empleados teletrabajando simultáneamente. Es decir, se permite un día de teletrabajo y los trabajadores deben organizarse para no coincidir. Actualmente todos los empleados tienen ordenador de sobremesa. En aplicación de la Ley 10/2021, se deberá proveer a los trabajadores de los medios para conectarse desde sus hogares. En estas condiciones, ¿cuál es la solución tecnológica más barata?

- A) Proporcionar a cada empleado un portátil barato (Chromebook o similar) y conexión RDP al ordenador de sobremesa.
- B) Proporcionar a cada empleado un portátil que se conecte mediante VPN.
- C) Proporcionar a cada empleado un portátil barato (Chromebook o similar) y conexión a una VDI.
- D) Proporcionar a cada empleado un portátil barato (Chromebook o similar) y conexión a un servicio de DaaS.

6. ¿Cuál de los siguientes no es un concepto definido en la Ley 10/2021?

- A) Trabajo a distancia.
- B) Trabajo en movilidad.
- C) Teletrabajo.
- D) Todos los anteriores están definidos en la Ley 10/2021.

7. En un organismo público cuya misión se relaciona con la seguridad nacional, existe un sistema de control de accesos por el cual, a los documentos con la etiqueta TOP SECRET sólo pueden acceder unos usuarios determinados, sobre los que se ha realizado un control estricto previo (antecedentes, historial, conocidos, etc.). Esto es un ejemplo de:

- A) RBAC
- B) MAC
- C) DAC
- D) ABAC

8. Una organización tradicional, con muchas aplicaciones antiguas ejecutándose en su CPD, ha empezado recientemente a utilizar el SaaS. Primero contrató una solución de ofimática en la nube, después un CRM en modalidad SaaS, luego una solución ITSM en la nube, y ahora se plantea una aplicación de contabilidad y facturación también en la nube. Sin embargo, los usuarios se quejan de que tienen que introducir muchas contraseñas y las políticas son diferentes en cada aplicación. La organización había resuelto este problema en sus aplicaciones tradicionales utilizando Microsoft Active Directory, que está instalado en su CPD en alta disponibilidad. ¿Cuál de las siguientes soluciones recomendaría?

- A) Desarrollar scripts a medida que cada noche accedan a cada uno de los servicios en nube y carguen los usuarios y contraseñas del AD local en la base de datos de cada proveedor de servicios de nube.
- B) Contratar un servicio de identidad en la nube capaz de realizar SSO y federarlo con el servicio de directorio local.
- C) Desplegar en local un servidor RADIUS y delegar la autenticación de todos los sitios web a este servidor, que consultará con el servicio de directorio local.
- D) Dejar de contratar tantos servicios en la nube y volver al modelo tradicional, con todas las aplicaciones en local, que estaba funcionando perfectamente hasta que los jefes empezaron a innovar.

9. Una de las Áreas de Desarrollo de su organización está trabajando en una nueva aplicación que va a ser útil para todos los ciudadanos españoles. Le preguntan qué tecnología deberían usar para la autenticación, de entre las siguientes:

- A) Hacer un desarrollo a medida utilizando las funcionalidades de Spring para la gestión de identidades. En el equipo de desarrollo hay una chica que es una *crack* y dice que lo puede hacer en dos semanas, con lo que sería la opción más barata y que proporciona el máximo control.
- B) Utilizar el servicio de directorio de la organización.

C) Contratar un servicio de IAM en la nube. Se habla de Okta, que es un líder según muchos estudios, aunque es algo caro.

D) Ninguna de las anteriores.

10. Una organización ha implantado el SSO en las aplicaciones y servicios que se sirven desde su red de área local. La Responsable de Seguridad de la organización, sin embargo, insiste mucho en que es importante implantar también múltiples factores de autenticación, porque sólo usuario y contraseña es peligroso. Indique cuál de las siguientes no es una opción válida:

A) Se puede implantar el MFA instalando un servidor RADIUS y un servidor o pasarela de SMS. Cada usuario deberá registrar su número de teléfono y la doble autenticación se haría mediante el envío de SMS. Existen productos en el mercado que se pueden adquirir para implantar la solución completa.

B) Se puede implantar el MFA instalando un servidor RADIUS y utilizando tokens físicos que se reparten a los usuarios. El token es una pequeña cajita con un botón y una pantallita, que el usuario puede guardar en su llavero. Cuando el usuario quiere autenticarse, pulsa el botón y en la pantallita aparece un número, diferente cada vez. Introduce el número en el ordenador. Existen productos en el mercado que se pueden adquirir para implantar la solución completa.

C) Se puede implantar el MFA instalando un servidor RADIUS y utilizando una app que el usuario debe instalar en su teléfono (personal o corporativo). La doble autenticación se haría mediante un código que aparece en el teléfono, o escaneando un código QR, o por cualquier otra interacción con la app. Existen productos en el mercado que se pueden adquirir para implantar la solución completa.

D) Se puede implantar el MFA contratando una solución IAM moderna en la nube, que sea capaz de realizar la autenticación del usuario y enviando un token SAML compatible con Kerberos. Con esto se ahorra el coste de instalar y mantener un servidor RADIUS, y la organización ya estará preparada para los entornos modernos de nube híbrida y múltiples proveedores. Existen productos en el mercado que se pueden contratar y proporcionan la solución completa.

10. Respuestas a las preguntas de test

Pregunta 1: respuesta C. Es la única indispensable, aunque tanto la capacidad de realizar la autenticación multifactor como la capacidad de realizar SSO web y de automatizar los procedimientos manuales pueden llegar a ser todas ellas deseables, dependiendo del contexto de la organización.

Pregunta 2: respuesta D. El coste de las licencias de ofimática es el mismo en todos los casos y sería un coste temporal (suscripción por dos meses, que no se renueva transcurrido este plazo). El coste de 250 ordenadores durante 5 semanas en DaaS es menor que comprar 250 físicos, y a su vez este coste es menor que el de comprar la infraestructura de VDI (servidores, cabinas, licencias).

Pregunta 3: respuesta C. RADIUS es un protocolo para la autenticación y autorización, incluyendo el uso de múltiples factores de autenticación, pero no sirve para establecer túneles seguros (es decir, conexiones VPN).

Pregunta 4: respuesta C. OAuth 2 sólo permite la autorización, no la autenticación, por lo que no se puede usar para la federación de identidades. CHAP permite la autenticación, pero no la federación.

Pregunta 5: respuesta A. Con esta opción sólo hay que comprar tantos Chromebook como empleados. Con la opción B, el coste es más elevado porque un portátil que va a ser utilizado como ordenador principal tendrá, normalmente, mejores características que un Chromebook y será más caro. Con la opción C, además de los Chromebook hay que adquirir la infraestructura para la VDI (servidores, almacenamiento, licencias de virtualización y escritorio virtual). Con la opción D pasa lo mismo, además del Chromebook hay que pagar al proveedor de servicios de nube.

Pregunta 6: respuesta B. El trabajo en movilidad no es un concepto definido en la Ley 10/2021.

Pregunta 7: respuesta B. Si fuera DAC, cada usuario podría conceder los permisos sobre los ficheros de los que es administrador. Si fuera ABAC, el acceso dependería de algún atributo del usuario. Ídem si fuera RBAC, en donde el acceso dependería de que el usuario pertenezca a determinado grupo.

Pregunta 8: respuesta B. La primera opción es muy mala idea, porque cada vez que algún proveedor de nube haga algún cambio en la autenticación o las tablas, podría dejar de funcionar el script, lo que supondría mal servicio a los usuarios y altos costes en mantenimiento de esta solución. La opción C sería posible, pero sólo si todos los proveedores de nube lo permiten. Incluso si los que tenemos hoy lo permiten, en el futuro podemos tener otros que no lo permitan. En todo caso, esta solución no resuelve las altas y bajas, es decir, la identidad, sino únicamente la autenticación, por lo que también tendría muchos problemas (¿cómo trasladar el alta de un nuevo usuario a todos los proveedores de nube?).

Pregunta 9: respuesta D. En general, se debe evitar desarrollar las soluciones IAM manualmente, porque es mucho más trabajo del que parece y es mucho más complejo de lo que parece, además

de que, si se producen vulnerabilidades, las consecuencias serían gravísimas. En cuanto a la B, no tiene sentido mezclar los datos de 47M de ciudadanos con los de la organización, además de que no está nada claro cómo se haría el alta y la baja de cada uno de estos 47 millones de ciudadanos en el servicio de directorio del Ministerio. En cuanto a la C, presenta exactamente el mismo problema. Lo ideal en el caso descrito sería usar Cl@ve, que mediante el protocolo SAML sirve para la autenticación de los ciudadanos españoles.

Pregunta 10: respuesta D. Las tres primeras opciones son ciertas, y existen numerosos productos en el mercado que permiten la autenticación mediante SMS, app o token físico. En cambio, la última pregunta es falsa, porque no tiene sentido enviar un token SAML a una red Kerberos. Existen soluciones IAM que ofrecen agentes para instalar en la red interna, pero en todo caso SAML y Kerberos no son compatibles entre sí y se necesitaría algún tipo de solución diferente del token SAML.

11. Glosario

AAA: Authentication, Authorization and Accounting, autenticación, autorización y registro de auditoría

AAPP: Administraciones Públicas

ABAC: Attribute Based Access Control, control de accesos basado en atributos

AC: Autoridad de Certificación

ACE: Access Control Entry, entrada en la lista de control de accesos

ACL: Access Control List, lista de control de accesos

ADCS: Active Directory Certification Services, servicios de certificación de AD (Directorio Activo)

ADFS: Active Directory Federation Services, servicios de federación de AD (Directorio Activo)

AGE: Administración General del Estado

API: Application Programming Interface, interfaz para la programación de aplicación

CAU: Centro de Atención al Usuario

CCN: Centro Criptológico Nacional

CHAP: Challenge Handshake Authentication Protocol, protocolo de autenticación por desafío mutuo

CPD: centro de procesamiento de datos

CRM: Customer Relationship Management, aplicación para la gestión de clientes

DaaS: Desktop as a Service, modalidad de puesta a disposición de escritorios virtuales desde infraestructura gestionada por terceros

DAC: Discretionary Access Control, control discrecional de accesos

DLP: Data Loss Prevention, sistemas para evitar la fuga de datos fuera de la organización

DMZ: Demilitarized Zone, zona desmilitarizada

IaaS: Infrastructure as a Service, modalidad de puesta a disposición de infraestructura gestionada por terceros

IAM: Identity and Access Management, Gestión de Identidad y Accesos

IdP: Identity Provider, proveedor de identidad

IDS: Intrusion Detection System, sistema para la detección de intrusiones

IP: Internet Protocol, protocolo de direccionamiento en Internet

IPS: Intrusion Prevention System, sistema para evitar intrusiones

ITSM: IT Service Management, aplicación para la gestión de los servicios ofrecidos por el departamento TIC de una organización

JWT: JSON Web Token, token web en formato JSON

LAN: Local Area Network, red de área local

LDAP: Lightweight Directory Access Protocol, protocolo ligero de acceso a directorios

MAC: Mandatory Access Control, control obligatorio de accesos

OIDC: OpenID Connect, protocolo de autenticación web

PAP: Password Authentication Protocol, protocolo para autenticación de contraseñas

PC: Personal Computer, ordenador personal

PKCE: Proof Key for Code Exchange, clave de comprobación para intercambio de códigos

PKI: Public Key Infrastructure, infraestructura de clave pública

RAdAC: Risk Adaptive Access Control, control de accesos basado en la adaptación al riesgo

RADIUS: Remote Authentication Dial-In User Service, protocolo de autenticación y autorización para el acceso remoto

RBAC: Role-based Access Control, control de accesos basado en roles

RDP: Remote Desktop Protocol, protocolo para el escritorio remoto

RRHH: Recursos Humanos

SaaS: Software as a Service, modalidad de puesta a disposición del software como servicio, es decir, desde infraestructura gestionada por terceros

SAML: Security Assertion Markup Language, lenguaje de marcado para aserciones de seguridad

SP: Service Provider, proveedor de servicios

SSO: Single Sign-On, acceso unificado

TACACS: Terminal Access Controller Access Control Server, servidor de control de accesos para controlador de accesos de terminales

TIC: Tecnologías de la Información y las Comunicaciones

UDP: User Datagram Protocol, protocolo de datagramas del usuario

UEM: Unified Endpoint Management, gestión unificada de dispositivos

VDI: Virtual Desktop Infrastructure, infraestructura de escritorio virtual

VPN: Virtual Private Network, red privada virtual

XTACACS: Extended TACACS, TACACS extendido

12. Bibliografía

- Access Control and Identity Management, 3rd Edition, Mike Chapple, Ed. Jones & Bartlett Learning, 2020.
- Solving Identity Management in Modern Applications: Demystifying Oauth 2, OpenID Connect and SAML 2, Yvonne Wilson y Abhishek Hingnikar, Ed. Apress, 2022.
- Magic Quadrant for Access Management, Henrique Teixeira, Abhyuday Data y más, Ed. Gartner, 2022. Consultada la versión "Licensed for Distribution".
- Mastering Active Directory, 3rd Edition, Dishan Francis, Ed. Packt Publishing, 2021.
- <https://www.okta.com/workforce-identity/>
- <https://docs.pingidentity.com/>
- <https://azure.microsoft.com/es-es/products/active-directory#features>
- <https://www.thalesgroup.com/en/markets/digital-identity-and-security/government/identity/id-management-system>
- <https://administracionelectronica.gob.es/ctt/verPestanaGeneral.htm?idIniciativa=clave>
- https://commission.europa.eu/strategy-and-policy/priorities-2019-2024/europe-fit-digital-age/european-digital-identity_en
- <https://www.manageengine.com/products/ad-manager/>